

SPCI106

POSTGRADUATE COURSE

M.Sc. - Cyber Forensics & Information Security

FIRST YEAR

SECOND SEMESTER

CORE PAPER - V

**NETWORK SECURITY AND
CRYPTOGRAPHY**



**INSTITUTE OF DISTANCE EDUCATION
UNIVERSITY OF MADRAS**

WELCOME

Warm Greetings.

It is with a great pleasure to welcome you as a student of Institute of Distance Education, University of Madras. It is a proud moment for the Institute of distance education as you are entering into a cafeteria system of learning process as envisaged by the University Grants Commission. Yes, we have framed and introduced Choice Based Credit System(CBCS) in Semester pattern from the academic year 2018-19. You are free to choose courses, as per the Regulations, to attain the target of total number of credits set for each course and also each degree programme. What is a credit? To earn one credit in a semester you have to spend 30 hours of learning process. Each course has a weightage in terms of credits. Credits are assigned by taking into account of its level of subject content. For instance, if one particular course or paper has 4 credits then you have to spend 120 hours of self-learning in a semester. You are advised to plan the strategy to devote hours of self-study in the learning process. You will be assessed periodically by means of tests, assignments and quizzes either in class room or laboratory or field work. In the case of PG (UG), Continuous Internal Assessment for 20(25) percentage and End Semester University Examination for 80 (75) percentage of the maximum score for a course / paper. The theory paper in the end semester examination will bring out your various skills: namely basic knowledge about subject, memory recall, application, analysis, comprehension and descriptive writing. We will always have in mind while training you in conducting experiments, analyzing the performance during laboratory work, and observing the outcomes to bring out the truth from the experiment, and we measure these skills in the end semester examination. You will be guided by well experienced faculty.

I invite you to join the CBCS in Semester System to gain rich knowledge leisurely at your will and wish. Choose the right courses at right times so as to erect your flag of success. We always encourage and enlighten to excel and empower. We are the cross bearers to make you a torch bearer to have a bright future.

With best wishes from mind and heart,

DIRECTOR i/c

M.Sc. Cyber Forensics & Information Security
FIRST YEAR - SECOND SEMESTER

CORE PAPER - V
NETWORK SECURITY AND
CRYPTOGRAPHY

**COURSE COMPILED, WRITTEN &
EDITED BY**

Dr. N. Kala
Director i/c
Cyber Forensics and Information Security,
University of Madras
Chennai

M.Sc. DEGREE COURSE

FIRST YEAR

SECOND SEMESTER

Core Paper - V

NETWORK SECURITY AND CRYPTOGRAPHY

SYLLABUS

Unit 1 Network Security - The CIA Triad - DAD - Internet Key Exchange (IKE) - Internet Protocol Security (IPSec) - AH and ESP Header - Security Associations - Transport Layer Security (TLS) - Secure Electronic Transaction (SET) - Extensible Authentication Protocol (EAP) - Protected Extensible Authentication Protocol (PEAP) - Lightweight Extensible Authentication Protocol (LEAP) - Secure Multipurpose Internet Mail Extensions (S/MIME) - Pretty Good Privacy (PGP).

Unit 2 Point-to-Point Protocol (PPP) - Challenge Handshake Authentication Protocol (CHAP) - Password Authentication Protocol (PAP) - High Level Data link Control (HDLC) - Remote Authentication Dial-In User Service (RADIUS) - Terminal Access Controller Access-Control System (TACACS+) - Tunneling Protocols in the Data Link Layer - Layer 2 Forwarding (L2F) - Layer 2 Tunneling Protocol (L2TP) - Point-to-Point Tunneling Protocol (PPTP)

Unit 3 Security Threats and Vulnerabilities - Virus - Trojan - Rootkits - Backdoors - Botnets - Man in the middle attack - Dos and DDos - Replay attack - Spoofing - Spam - Phishing - privilege escalation - DNS poisoning - Brute force - Dictionary attack - Cross-site scripting - SQL injection - Zero-day attack - Session hijacking - Vulnerability scanning vs Port Scanning - Honeypots - Banner grabbing - Social Engineering.

Unit 4 Cryptology - Cryptosystems - Symmetric vs asymmetric cryptosystem, Goals of Cryptography - Confidentiality, Integrity and Non-repudiation - Ciphers, (Block ciphers and stream ciphers), Transposition Ciphers - Substitution Ciphers - One-Time Pads - Codes vs. Ciphers - Cryptographic keys, - Hashing Algorithms - IPSec - AH and ESP - Security Associations - ISAKMP. Wireless Network security, WEP, WPA, WPA2, TKIP - CCMP.

Unit 5 Symmetric Key Algorithms - Data Encryption Standard (DES) - DES Keys - DES Algorithm - Electronic Codebook Mode - Cipher Block Chaining Mode - Cipher Feedback Mode - Output Feedback Mode - Counter Mode - Triple DES (3DES) - DES Variants - DES-EEE3 - DES-EDE3 - DES-EEE2 - DES-EDE2 - International Data Encryption Algorithm (IDEA) - Blowfish - Skipjack - Advanced Encryption Standard (AES) - CAST - Password hashes and Salting - Asymmetric Key Algorithms - RSA - Diffie-Hellman - Private key and Public key - Digital Signature - Public Key Infrastructure (PKI) - Certificate Authorities - Certification Revocation List (CRL) - Digital Signature.

M.Sc. DEGREE COURSE
FIRST YEAR
SECOND SEMESTER
Core Paper - V
NETWORK SECURITY AND CRYPTOGRAPHY
SCHEME OF LESSONS

Sl.No.	Title	Page
1	Introduction to Network Security	1
2	Common Authentication Protocols	19
3	Real World Protocols	33
4	Virtual Private Networks	43
5	MPLs and MPLs VPN	50
6	Securing Wireless Networks	63
7	AD-HOC Network Security	83
8	RFID Security	92

Lesson - 1

Introduction to Network Security

Learning Objectives

After reading this lesson you will be able to understanding the following:

- Network Layer Devices
- Network Layer Attacks
- Firewall
- Intrusion Detection System (IDS), Intrusion Prevention System (IPS) and types

Structure

- 1.1 Network Layer Devices**
- 1.2 Network Layer Attacks**
- 1.3 Firewall**
- 1.4 Intrusion Detection Systems, Intrusion prevention systems and types**

1.1 Network Layer Devices

Layer 1:

Hub:

Hub is a networking device which is used to connect multiple network hosts. A network hub is also used to do data transfer. The data is transferred in terms of packets on a computer network. So, when a host sends a data packet to a network hub, the hub copies the data packet to all of its ports which are connected to the hosts. Like this, all the ports know about the data and the port for whom the packet is intended, claims the packet.

However, because of its working mechanism, a hub is not so secure and safe. Moreover, copying the data packets on all the interfaces or ports makes it slower and more congested which led to the use of network switch.

Network Interface Card (NIC)

A NIC is a component that provides networking capabilities for a computer. It may enable a wired connection (such as Ethernet) or a wireless connection (such as Wi-Fi) to a local area network.

The NIC is both a physical layer and data link layer device, as it provides physical access to a networking medium and, for IEEE 802 and similar networks, provides a low-level addressing system through the use of Media Access Control (MAC) addresses that are uniquely assigned to network interfaces.

Layer 2:

Switch:

A network switch also connects computers to each other, like a hub. Where the switch differs from a hub is in the way it handles packets of data. While hub just does the work of data forwarding, a switch does 'filter and forwarding' which is a more intelligent way of dealing with the data packets. So, when a packet is received at one of the interfaces of the switch, it filters the packet and sends only to the interface of the intended receiver.

For this purpose, a switch also maintains a CAM (Content Addressable Memory) table and has its own system configuration and memory. CAM table is also called as forwarding table or forwarding information base (FIB).

It does not broadcast the packet to all computers as a hub does which means bandwidth is not shared and makes the network much more efficient.

Bridge:

A network bridge is a computer networking device that creates a single aggregate network from multiple communication networks or network segments. This function is called network bridging.

Repeater:

A repeater is an electronic device that amplifies the signal it receives. In other terms, repeater is a device which receives a signal and retransmits it at a higher level or higher power so that the signal can cover longer distances.

For example, inside a college campus, the hostels might be far away from the main college where the ISP line comes in. If the college authority wants to pull a wire in between the hostels and main campus, they will have to use repeaters if the distance is much because different types of cables have limitations in terms of the distances, they can carry the data for.

Layer 3:

Router:

Its primary function is to route data packets to other networks, instead of just the local computers. A router bridges the gap between other networks and gives your network access to more features, e.g., a firewall, traffic monitoring, VPN, and more.

Routers contain a processor (CPU), several kinds of digital memory, and input-output (I/O) interfaces. They function as special-purpose computers, one that does not require a keyboard or display.

Routers also maintain configuration information in a part of memory called the routing table, routers also can filter both incoming or outgoing traffic based on the addresses of senders and receivers.

Firewall:

A firewall is a network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Firewalls are the first line of defense in the network security. They establish a barrier between secured and controlled internal networks that can be trusted and untrusted outside networks, such as the Internet.

A firewall can be hardware, software, or both.

1.2 Network Layer Attacks

The following are the major attacks at the Network Layer associated with the IP:

1. IP Spoofing
2. Routing (RIP) Attacks
3. ICMP Attacks

4. PING Flood (ICMP Flood)
5. Ping of Death Attack
6. Teardrop Attack
7. Sniffing Attack

1. IP Spoofing:

IP spoofing is the creation of Internet Protocol (IP) packets which have a modified source address in order to either hide the identity of the sender, to impersonate another computer system, or both. It is a technique often used by bad actors to invoke Distributed Denial of Service attacks (DDoS) attacks against a target device or the surrounding infrastructure.

Sending and receiving IP packets is a primary way in which networked computers and other devices communicate, and constitutes the basis of the modern internet. All IP packets contain a header which precedes the body of the packet and contains important routing information, including the source address. In a normal packet, the source IP address is the address of the sender of the packet. If the packet has been spoofed, the source address will be forged.

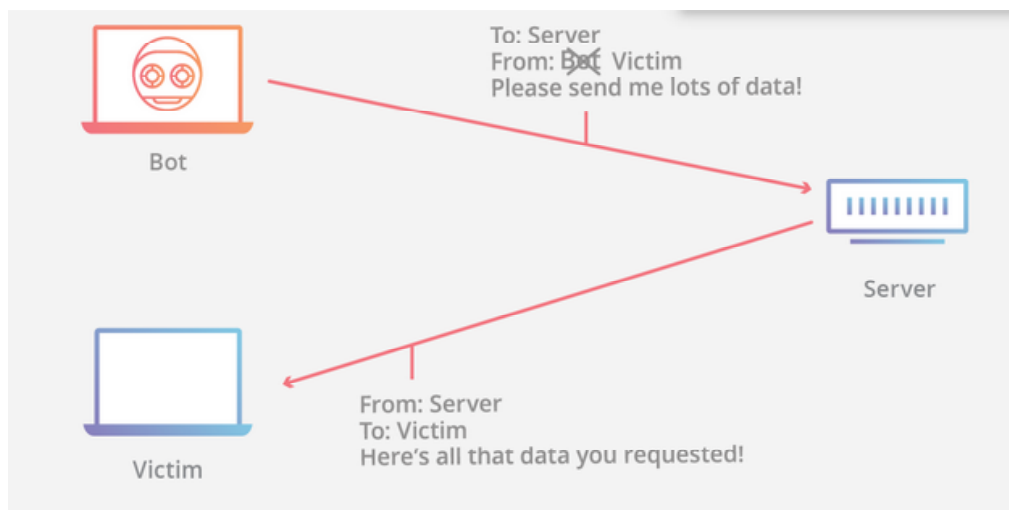


Figure 1.1: Demonstrating IP spoofing

Mitigations:

- § Create Input access-lists; which filters at the ingress interfaces. It also protects the router itself from spoofing attacks.
- § Unicast Reverse Path Forwarding (uRPF) is a common technique used to mitigate source address spoofing by discarding the IP Packets that lack a verifiable IP source address in the IP Routing Table.
- § IP Source Guard is a Layer 2 security feature that prevents IP spoofing attacks by restricting IP traffic on untrusted Layer 2 ports to clients with an assigned IP address.

2. Routing (RIP) Attack

Routing Information Protocol (RIP) is used to distribute routing information within networks, such as shortest-paths, and advertising routes out from the local network. The original version of RIP has no built-in authentication, and the information provided in a RIP packet is often used without verifying it. An attacker could forge a RIP packet, claiming his host “X” has the fastest path out of the network. All packets sent out from that network would then be routed through X, where they could be modified or examined. An attacker could also use RIP to effectively impersonate any host, by causing all traffic sent to that host to be sent to the attacker’s machine instead.

Mitigations:

- § The version 2 of RIP was enhanced with a simple password authentication algorithm, which makes RIP attacks harder to perform.
- § IPSec VPN provides a way to keep routing information encrypted among the routers implementing the IPsec VPN.

In this era of cryptocurrency, Bitcoins constitutes a target of choice for attackers, attacking the currency via the Internet routing infrastructure itself. By manipulating routing advertisement(BGP hijacks) or by naturally intercepting traffics Autonomous Systems can intercept and manipulate a large fraction of bitcoin traffic.

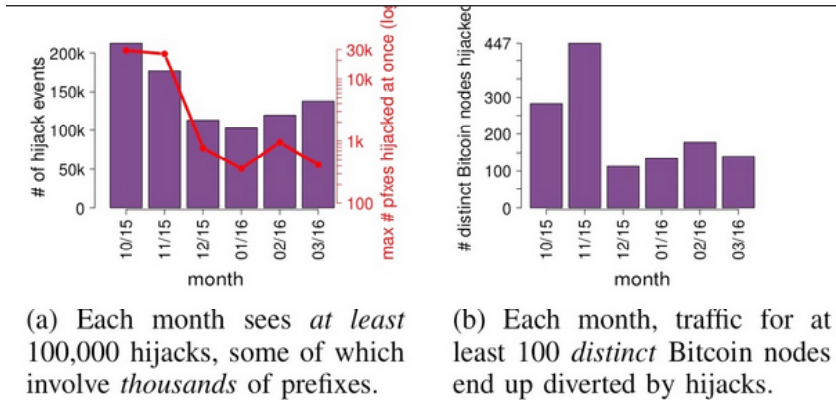


Figure 1.2: Routing manipulation (BGP hijacks) are prevalent today and impact Bitcoin.

3. Internet Control Message Protocol (ICMP) Attack:

ICMP is used by the IP layer to send one-way informational messages to a host. There is no authentication in ICMP, which leads to attacks using ICMP that can result in a denial of service, or allowing the attacker to intercept packets. An attacker sends forged ICMP echo packets to vulnerable networks' broadcast addresses. All the systems on those networks send ICMP echo replies to the victim, consuming the target system's available bandwidth and creating a denial of service (DoS) to legitimate traffic.

Smurf attacks use whole networks of computers to direct an overwhelming amount of traffic to a victim's machine and its network.

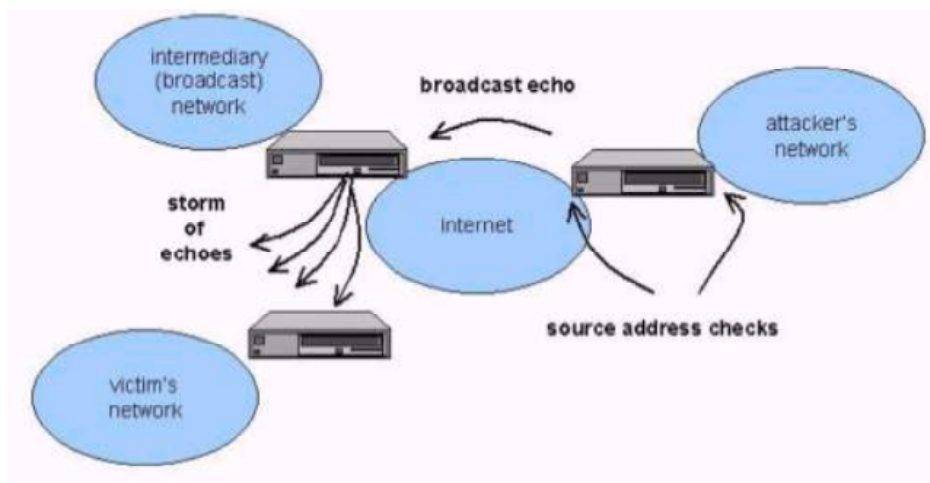


Figure 1.3: SMURF ATTACK

Mitigations:

- § Most ICMP attacks can be effectively reduced by deploying Firewalls at critical locations of a network to filter un-wanted traffic and from any destinations.
- § In addition, to keep a reasonable balance between services and security, you should configure your ICMP parameters in your network devices as follows:
 - a. Allow ping ICMP Echo-Request outbound and Echo-Reply messages inbound.
 - b. Allow traceroute TTL-Exceeded and Port-Unreachable messages inbound.
 - c. Allow path MTU ICMP Fragmentation-DF-Set messages inbound.
 - d. Blocking other types of ICMP traffic.

4. PING Flood (ICMP Flood):

PING is one of the most common uses of ICMP which sends an ICMP “Echo Request” to a host, and waits for that host to send back an ICMP “Echo Reply” message. The attacker simply sends a huge number of “ICMP Echo Requests” typically overloading its victim that it expends all its resources to respond until it can no longer process valid network traffic. By flooding the target host with great amounts of ICMP messages will leave the attacked host and its associated network with degraded performance or even total denial of service in some instance.

Mitigations:

- § The most obvious way to mitigate an ICMP/PING Flood is to block ICMP altogether at the perimeter of your network via firewall filters.
- § By limiting the rate at which a single source can send ICMP Packets. This threshold is per second.

5. Ping of Death Attack:

The principle of ping of death simply involves creating an IP datagram whose total size exceeds the maximum authorized size (65,536 bytes). When such a packet is sent to a system with a vulnerable TCP/IP stack, it will cause the system to crash.

Ping of Death attacks are particularly effective because the attacker’s identity could be easily spoofed. Moreover, a Ping of Death attacker would need no detailed knowledge of the machine he/she was attacking, except for its IP address.

Mitigations:

§ All the recent and latest OSs are not vulnerable to this attack.

6. Teardrop Attack:

A teardrop attack is a denial-of-service (DoS) attack that involves sending fragmented packets to a target machine. Since the machine receiving such packets cannot reassemble them due to a bug in TCP/IP fragmentation reassembly, the packets overlap one another, crashing the target network device. This generally happens on older operating systems.

One of the fields in an IP header is the “fragment offset” field, indicating the starting position, or offset, of the data contained in a fragmented packet relative to the data in the original packet. If the sum of the offset and size of one fragmented packet differs from that of the next fragmented packet, the packets overlap. When this happens, a server vulnerable to teardrop attacks is unable to reassemble the packets - resulting in a denial-of-service condition.

Mitigations:

§ A simple reboot is the preferred remedy after this happens.

§ Recent systems are not vulnerable to this attack.

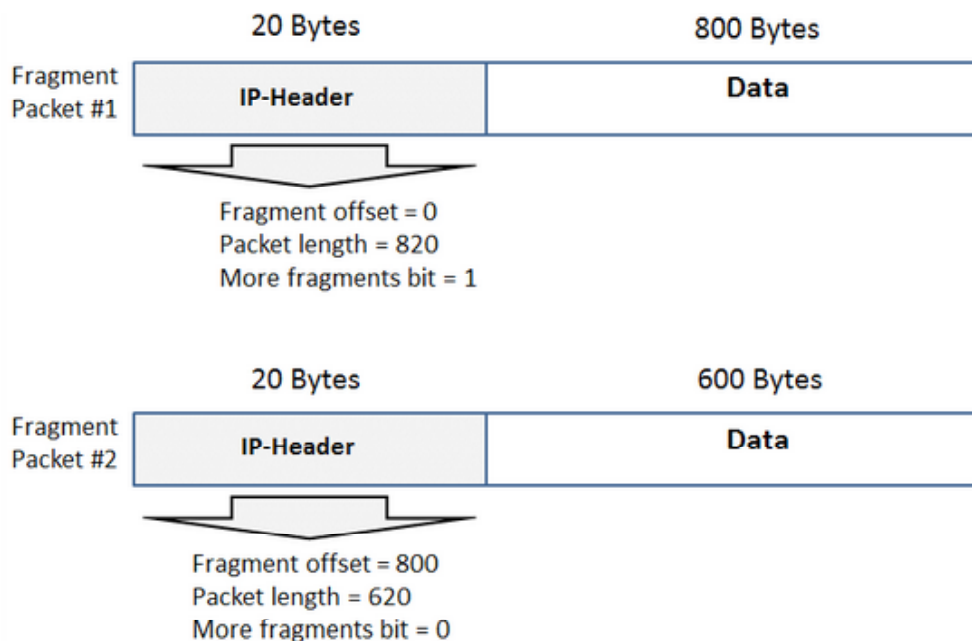


Figure 1.4: Teardrop attack

7. Sniffing attacks:

Because most network applications distribute network packets in clear text, a packet sniffing tool can exploit information passed in clear text providing the hacker with sensitive information such as user account names and passwords.

There are various types of sniffing attack such as –

- LAN Sniff – The sniffer attacks the internal LAN and scans the entire IP gaining access to live hosts, open ports, server inventory etc.. A port specific vulnerability attacks happens in LAN sniffing.
- Protocol Sniff – Based on the network protocol used, the sniffer attacks occur. The different protocol such as ICMP, UDP, Telnet, PPP, DNS etc. or other protocols might be used.
- ARP Sniff – ARP Poisoning attacks or packet spoofing attacks occur based on the data captured to create a map of IP address and associated MAC addresses.
- TCP Session stealing – TCP session stealing is used to monitor and acquire traffic details between the source & destination IP address. All details such as port number, service type, TCP sequence numbers, data are stolen by the hackers.
- Application level sniffing – Applications running on the server are attacked to plan an application specific attack.
- Web password sniffing – HTTP session created by users are stolen by sniffers to get the user ID, password and other sensitive information.

Mitigations:

- § Authentication - Using strong authentication, such as one-time passwords.
- § Cryptography - The most effective method for countering packet sniffers renders them irrelevant.
- § Switched Infrastructure - Deploy a switched infrastructure to counter the use of packet sniffers in your environment.
- § Anti-sniffer tools - Use these tools to employ software and hardware designed to detect the use of sniffers on a network.

Public Wi-Fi Sniffer attack

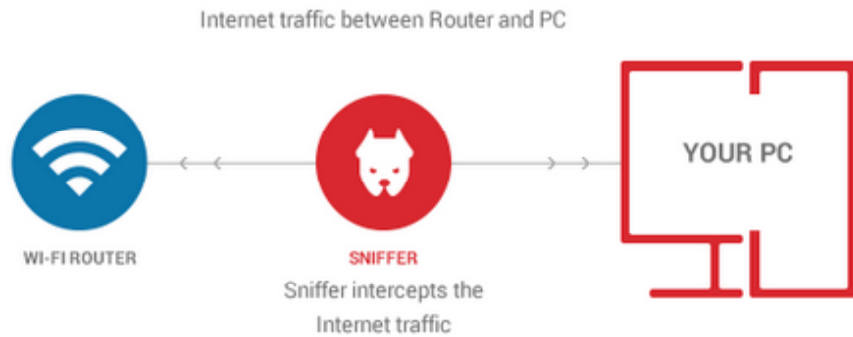


Figure 1.5: Wi-Fi Sniffer attack

1.3 Firewall

A firewall is a network device used to block or filter traffic. It is typically deployed between a private network and a link to the internet, but it can be deployed between departments within an organization.

Firewalls are essential tools in managing and controlling network traffic. Without firewalls, it would not be possible to prevent malicious traffic from the internet from entering into private networks.

Firewalls filter traffic based on a defined set of rules, also called filters or Access Control Lists.

They are most effective against unrequested traffic and attempts to connect from outside the private network and can also be used for blocking known malicious data, messages, or packets based on content, application, protocol, port, or source address.

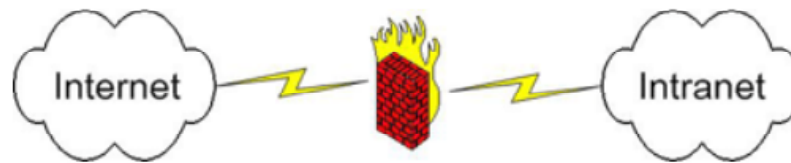


Fig 1.6- Firewall

Types of Firewall:

Packet Filtering:

The firewall performs a simple check of the data packets coming through the router—inspecting information such as the destination and origination IP address, packet type, port number, and other surface-level information without opening up the packet to inspect its contents. If the information packet doesn't pass the inspection, it is dropped.

These firewalls aren't very resource-intensive. This means they don't have a huge impact on system performance and are relatively simple. However, they're also relatively easy to bypass compared to firewalls with more robust inspection capabilities.

Stateful Inspection Firewalls

Stateful firewalls are able to determine the connection state of packets. the firewall remembers "state" (details of currently established connection) about expected return packets.

Any unexpected packet arriving at the firewall claiming to be a solicited response is blocked immediately.

However, these firewalls put more strain on computing resource. This may slow down the transfer of legitimate packets compared to the other solutions.

Application-level Gateway

The firewalls operate at the application layer to filter incoming traffic between private network and the traffic source. Rather than letting traffic connect directly, the firewall first establishes a connection to the source of the traffic and inspects the incoming data packet.

They may also perform deep-layer packet inspections, checking the actual contents of the information packet to verify that it contains no malware.

However, they can create significant slowdown because of the extra steps in the data packet transferal process.

Access Control Lists (ACL):

An ACL specifies which users or system processes are granted access to objects, as well as what operations are allowed on given objects.

A standard ACL can permit or deny traffic based only on the source address(s).

An extended ACL can permit or deny traffic based on both the source and destination address(s) as well as TCP/UDP/ICMP traffic types.

De-Militarized Zone (DMZ):

DMZ is a physical or logical subnetwork that contains and exposes an organization's external-facing services to an untrusted network, usually a larger network such as the Internet. The purpose of a DMZ is to add an additional layer of security to an organization's local area network (LAN).

It acts as a gateway to the public Internet, is neither as secure as the internal network, nor as insecure as the public internet.

1.4 Intrusion Detection System (IDS), Intrusion Prevention System (IPS) and types

Intrusion Detection System (IDS):

Intrusion Detection (ID) is the process of monitoring for and identifying attempted unauthorized system access or manipulation. An IDS gathers and analyzes information from diverse areas within a computer or a network to identify possible security breaches which include both intrusions (attack from outside the organization) and misuse (attack from within the organization). It inspects all the inbound and outbound network activity.

The IDS identifies suspicious patterns that may indicate an attack the system and acts as a security check on all transactions that take place in and out of the system.

An IDS can be configured for either a network or a specific device. A network intrusion detection system (NIDS) monitors inbound and outbound traffic, as well as data transfers between systems within a network. NIDSes are often spread out across several different points in a network to make sure there are no loopholes where traffic may be unmonitored.

An IDS configured for a single device is called a host intrusion detection system, or HIDS. It monitors a single host for abnormal traffic patterns. For example, it may look for known viruses or malware in both inbound and outbound traffic. Some HIDS even check packets for important system files to make sure they are not modified or deleted.

Intrusion Prevention System (IPS):

An intrusion prevention system (IPS) is a tool that is used to sniff out malicious activity occurring over a network and/or system. Intrusion prevention systems can also be referred to as intrusion detection and prevention systems (IDPS). Intrusion prevention systems function by finding malicious activity, recording and reporting information about the malicious activity, and trying to block/stop the activity from occurring.

Intrusion prevention systems expand on the capabilities of intrusion detection systems (IDS), which serve the fundamental purpose of monitoring network and system traffic. What makes intrusion prevention systems more advanced than intrusion detection systems is that IPS are located in-line (directly in the path in which the source and destination communicate) and have the capability to prevent or block the malicious activity that is occurring.

Types:

Host-Based:

They analyze each system's behavior and can be installed on any system ranging from a desktop PC to a server. It is versatile.

In addition to detecting unauthorized insider activity, host-based systems are also effective at detecting unauthorized file modification.

This is also more platform centric, with more focus on Windows OS.

Network-Based:

They check every packet entering the network for the presence of anomalies and incorrect data. It generates alerts either at the IP or the application level based on the content.

They gain access to network traffic by connecting to a hub, a switch configured for port mirroring, or a network tap. The sensors are placed at choke points in the network to monitor, often in the demilitarized zone (DMZ) or at network borders. Sensors capture all network traffic and analyze the content of individual packets for malicious traffic.

It detects malicious activity such as DoS attacks, port scans or attempts of breach.

Signature-Based:

A signature-based IDS or IPS sensor looks for specific, predefined patterns (signatures) in network traffic.

It compares the network traffic to a database of known attacks, and triggers an alarm or prevents communication if a match is found.

The signature can be based on a single packet or a sequence of packets.

Anomaly-Based:

The type that warns users about intrusions depending upon the difference in current network traffic and normal activity are called as Anomaly Detection System. It usually catches the data from the network and applies its rules to the data or detects differences in them.

Anomaly-based or profile-based signatures typically look for network traffic that deviates from what is seen as “normal”.

Policy-Based:

In policy-based systems, the IDS or IPS sensor is preconfigured based on the network security policy. Any traffic detected outside the policy will generate an alarm or be dropped.

Creating a security policy requires detailed knowledge of the network traffic and is a time-consuming task.

Honeypot-Based:

Honeypot systems use a dummy server to attract attacks. The purpose of the honeypot approach is to distract attacks away from real network devices.

By staging different types of vulnerabilities in the honeypot server, incoming types of attacks and malicious traffic patterns can be analysed.

This analysis can be used to tune sensor signatures to detect new types of malicious network traffic.

Types	Advantages	Disadvantages
Signature-Based	• Easy configuration • Fewer false positives • Good signature design	• No detection of unknown signatures • Initially a lot of false positives • Signatures must be created, updated, and tuned
Policy-Based	• Simple and reliable • Customized policies • Can detect unknown attacks	• Generic output • Policy must be created
Anomaly-Based	• Easy configuration • Can detect unknown attacks	• Difficult to profile typical activity in large networks • Traffic profile must be constant
Honey Pot-Based	• Window to view attacks • Distract and confuse attackers • Slow down and avert attacks • Collect information about attack	• Dedicated Honey pot server • Honey pot server must not be trusted

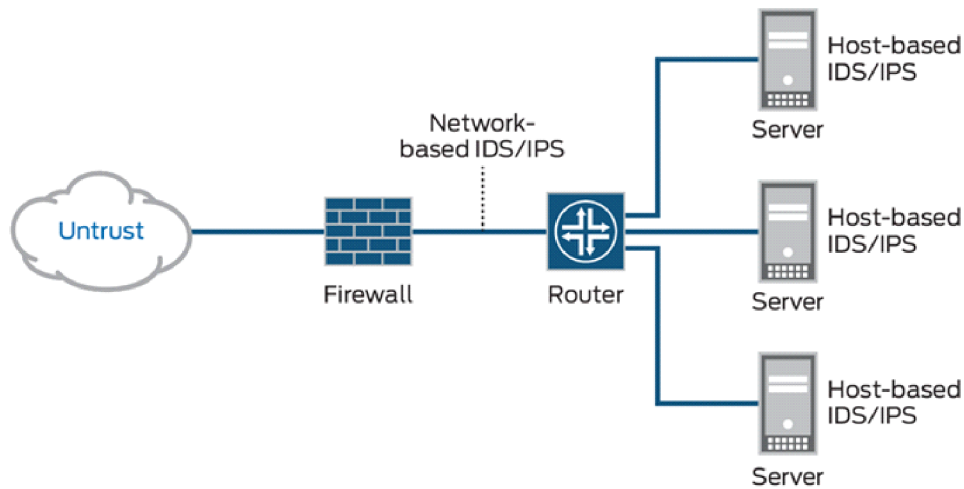


Figure 1.7: Position of IDS/IPS in a raw network architecture.

Summary

- Hub is a networking device which is used to connect multiple network hosts. It is also called a dumb device. No one uses hub these days, switch is used instead. Switch differs from a hub in the way it handles and forwards packets of data.
- A NIC is a component that provides networking capabilities for a computer. It may enable a wired connection (such as Ethernet) or a wireless connection (such as Wi-Fi) to a local area network.
- A repeater is an electronic device that amplifies the signal it receives. In other terms, repeater is a device which receives a signal and retransmits it at a higher level or higher power so that the signal can cover longer distances.
- Routers primary function is to route data packets to other networks, instead of just the local computers.
- IP spoofing is the creation of Internet Protocol (IP) packets which have a modified source address in order to either hide the identity of the sender, to impersonate another computer system, or both.
- Routing Information Protocol (RIP) is used to distribute routing information within networks, such as shortest-paths, and advertising routes out from the local network.

- Smurf attacks use whole networks of computers to direct an overwhelming amount of traffic to a victim's machine and its network.
- A teardrop attack is a denial-of-service (DoS) attack that involves sending fragmented packets to a target machine
- A firewall is a network device used to block or filter traffic. It is typically deployed between a private network and a link to the internet, but it can be deployed between departments within an organization.
- Intrusion Detection (ID) is the process of monitoring for and identifying attempted unauthorized system access or manipulation.
- An intrusion prevention system (IPS) is a tool that is used to sniff out malicious activity occurring over a network and/or system.

Check your Answers

- 1) Differentiate between stateful and stateless firewall.
- 2) Write short notes on: routers, switches and repeaters.
- 3) Differentiate between an IDS and an IPS.
- 4) What are the components needed for a secure network architecture?
- 5) Define SMURF attack.

References

<https://www.techopedia.com/definition/26350/hub-networking>

<http://networkmitigations.blogspot.com/2011/01/layer-3-network-layer-attacks.html>

<http://www.pearsonitcertification.com/articles/article.aspx?p=2861447>

<https://www.compuquip.com/blog/the-different-types-of-firewall-architectures>

<https://resources.infosecinstitute.com/network-design-firewall-idsips/#gref>

<https://www.ccexpert.us/scnd-2/types-of-ids-and-ips-sensors.html>

[https://en.wikipedia.org/wiki/DMZ_\(computing\)](https://en.wikipedia.org/wiki/DMZ_(computing))

<https://techterms.com/definition/nic>

<https://www.computerhope.com/issues/ch001559.htm>

<http://hackingdistributed.com/2017/05/01/bgp-attacks-on-btc/>

<https://www.sans.org/reading-room/whitepapers/threats/icmp-attacks-illustrated-477>

<https://security.radware.com/ddos-knowledge-center/ddospedia/teardrop-attack/>

<https://intellipaat.com/tutorial/ethical-hacking-cyber-security-tutorial/sniffing-attacks/>

<https://digitalguardian.com/resources/data-security-knowledge-base/intrusion-prevention-system>

Lesson – 2

Common Authentication Protocols

Learning Objectives

After reading this lesson you will be able to understanding the following:

- Authentication Concepts
- Various Authentication Protocols (PAP, CHAP, MS-CHAP)
- Remote Access with RADIUS and TACACS
- Single Sign On
- Kerberos
- Sesame
- Authentication in Wireless Networks

Structure

- 2.1 Authentication Concepts**
- 2.2 Various Authentication Protocols**
- 2.3 Remote Access with - RADIUS and TACACS**
- 2.4 Single Sign-on**
- 2.5 Kerberos**
- 2.6 Sesame**
- 2.7 Authentication in Wirelss - Networks**

2.1 Authentication Concepts

- Authentication is used by a server when the server needs to know exactly who is accessing their information or site.
- Authentication is used by a client when the client needs to know that the server is the system it claims to be.

- In authentication, the user or computer has to prove its identity to the server or client.
- Usually, authentication by a server entails the use of a user name and password. Other ways to authenticate can be through cards, retina scans, voice recognition, and fingerprints.
- Authentication by a client usually involves the server giving a certificate to the client in which a trusted third party such as Verisign or Thawte states that the server belongs to the entity (such as a bank) that the client expects it to.
- Authentication does not determine what tasks the individual can do or what files the individual can see. Authentication merely identifies and verifies who the person or system is.

2.2 Various Authentication Protocols

2.2.1 Password Authentication Protocol (PAP):

PAP is a simple user authentication protocol. It does not encrypt the data and sends the password and username in clear text.

It is very vulnerable to being read from the Point-to-Point Protocol (PPP). Among PAP's deficiencies is the fact that it transmits unencrypted passwords over the network. PAP is therefore used only as a last resort when the remote server does not support a stronger scheme.

Password Authentication Protocol (PAP) is a very basic two-way process. The username and password are sent in plain text, there is no encryption or protection. If it is accepted, the connection is allowed. PAP is not interactive in anyway, PAP is not considered a strong authentication protocol.

When the PPP authentication pap command is used, the username and password are sent as one LCP data package, rather than the server sending a login prompt and waiting for a response.

Password Authentication Protocol (PAP)

PAP 2-way handshake

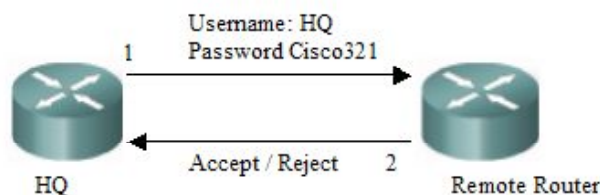


Figure 2.1: Password Authentication Protocol (PAP)

Link control protocol is a sub-protocol within the point-to-point protocol suite that is responsible for link management. LCP operates at the data-link-layer of OSI reference model for networking and is considered a data-link layer protocol. During establishment of a PPP communication session, LCP establishes the link, configures PPP options and tests the quality of the line between the PPP server. LCP automatically handles encapsulation format options & varies packet sizes over PPP communication links.

LCP also negotiates the type of Authentication Protocol used to establish the PPP. Different Authentication Protocols are supported for satisfying the security needs of different environments. LCP can negotiate the following Authentication Protocols.

- PAP - Transmits Password in clear text using 2-way handshake
- CHAP - passes a Password hash using 3-way handshake & is more secure than PAP.

2.2.2 Challenge-Handshake Authentication Protocol

CHAP authenticates a user or network host to an authenticating entity. That entity may be, for example, an Internet service provider.

CHAP provides protection against replay attacks by the peer through the use of an incrementally changing identifier and of a variable challenge-value. CHAP requires that both the client and server know the plaintext of the secret, although it is never sent over the network. Thus, CHAP provides better security as compared to Password Authentication Protocol (PAP) which is vulnerable for both these reasons. The MS-CHAP variant does not require either peers to know the plaintext and does not transmit it, but has been broken.

CHAP is an authentication scheme used by Point-to-Point Protocol (PPP) servers to validate the identity of remote clients. CHAP periodically verifies the identity of the client by using a three-way handshake. This happens at the time of establishing the initial link (LCP), and may happen again at any time afterwards. The verification is based on a shared secret (such as the client's password).

1. After the completion of the link establishment phase, the authenticator sends a "challenge" message to the peer.
2. The peer responds with a value calculated using a one-way hash function on the challenge and the secret combined.
3. The authenticator checks the response against its own calculation of the expected hash value. If the values match, the authenticator acknowledges the authentication. Otherwise it should terminate the connection.
4. At random intervals the authenticator sends a new challenge to the peer and repeats steps 1 through 3.

The Extensible Authentication Protocol Method for Microsoft Challenge Handshake Authentication Protocol (CHAP) is an EAP method that is designed to meet this need. It does so by having the client and server use MSCHAPv2 to mutually authenticate each other.

The flow for successful authentication with Extensible Authentication Protocol Method for Microsoft CHAP is as follows:

1. An EAP session is established between a client (EAP peer) and an EAP server.
2. The EAP server and EAP peer negotiate the EAP method to use. The Extensible Authentication Protocol Method for Microsoft CHAP is selected.
3. The EAP peer and EAP server continue to exchange EAP messages with MSCHAPv2 packets encapsulated in the payload.
4. After the MSCHAPv2 packets successfully authenticate the client and the server to each other, the EAP authentication finishes.

The Extensible Authentication Protocol Method for Microsoft CHAP is exposed to the same security threats as MSCHAPv2 and should be protected inside a secure tunnel, such as the one provided by PEAP [MS-PEAP].

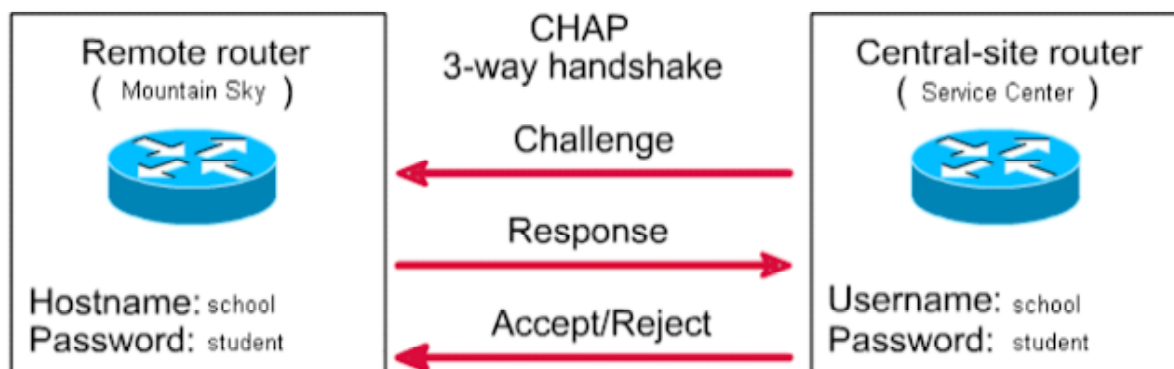


Figure2.2 : Challenge Handshake Authentication Protocol (CHAP)

2.3 Remote Access with RADIUS AND TACACS

RADIUS

Radius is a protocol for carrying information related to authentication, authorization, and configuration between a Network Access Server (NAS) that desires to authenticate its links and a shared Authentication Server.

RADIUS is an access server that uses AAA protocol (Authentication, Authorization, Accounting). It is a system of distributed security that secures remote access to networks and network services against unauthorized access. RADIUS comprises three components:

- A protocol with a frame format that utilizes User Datagram Protocol (UDP)/IP.
- A server.
- A client.

The server runs on a central computer typically at the customer's site, while the clients reside in the dial-up access servers and can be distributed throughout the network.

How does RADIUS Work?

1. User initiates PPP authentication to the Network Access Server (NAS).
2. NAS prompts for username and password (Either Password Authentication Protocol [PAP] or Challenge Handshake Authentication Protocol [CHAP]).

3. User replies.
4. RADIUS client sends username and encrypted password to the RADIUS server.
5. RADIUS server responds with Accept, Reject, or Challenge.
6. The RADIUS client acts upon services and services parameters bundled with Accept or Reject.

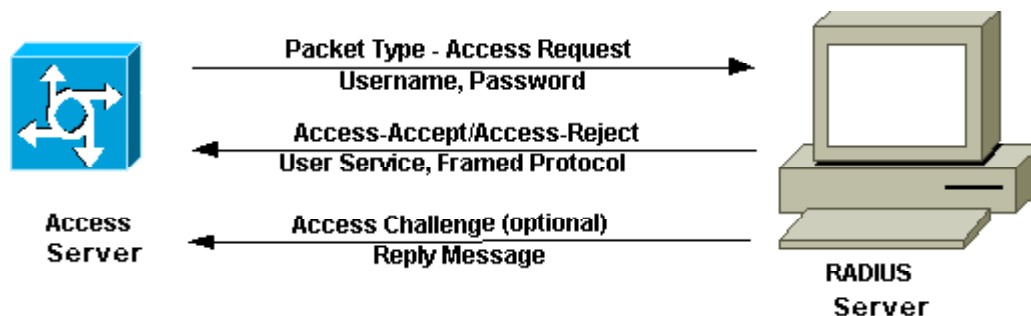


Figure 2.3: RADIUS

TACACS

TACACS (Terminal Access Controller Access Control System) is an older authentication protocol common to UNIX networks that allows a remote access server to forward a user's login password to an authentication server to determine whether access can be allowed to a given system. TACACS is an encryption protocol and therefore less secure than the later TACACS+ and Remote Authentication Dial-In User Service protocols. A later version of TACACS is XTACACS (Extended TACACS). Both are described in Request for Comments 1492.

In spite of its name, TACACS+ is an entirely new protocol. TACACS+ and RADIUS have generally replaced the earlier protocols in more recently built or updated networks. TACACS+ uses the Transmission Control Protocol (TCP) and RADIUS uses the User Datagram Protocol (UDP). Some administrators recommend using TACACS+ because TCP is seen as a more reliable protocol. Whereas RADIUS combines authentication and authorization in a user profile, TACACS+ separates the two operations.

TACACS and XTACACS are still running on many older systems.

The TACACS+ protocol separates the functions of Authentication, Authorization and Accounting. It allows for arbitrary length and content authentication exchanges, which will support any authentication mechanism to be utilized with TACACS+ clients. It is extensible to provide

for site customization and future development features, and it uses TCP to ensure reliable delivery. The protocol allows the TACACS+ client to request very fine-grained access control and allows the server to respond to each component of that request.

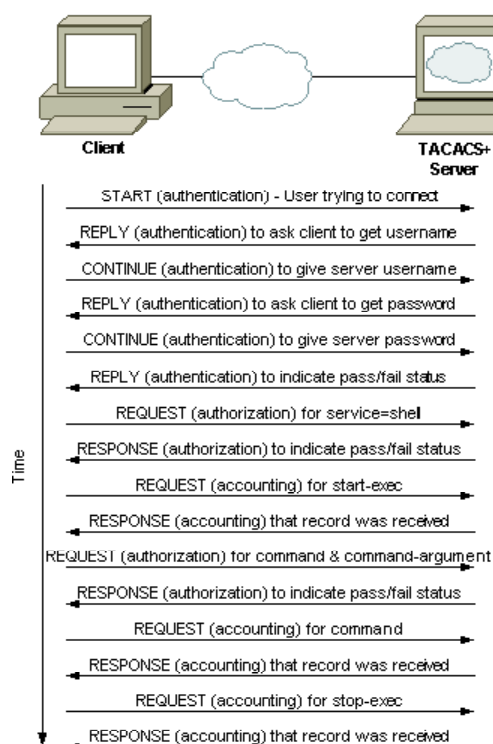


Figure 2.4: TACACS +

2.4 Single Sign On

Single sign-on (SSO) is a property of access control of multiple related, yet independent, software systems. With this property, a user logs in with a single ID and password to gain access to any of several related systems. It is often accomplished by using the Lightweight Directory Access Protocol (LDAP) and stored LDAP databases on (directory) servers. A simple version of single sign-on can be achieved over IP networks using cookies but only if the sites share a common DNS parent domain.

Systems requiring authentication for each application but using the same credentials from a directory server can be referred as Directory Server Authentication and systems where

a single authentication provides access to multiple applications by passing the authentication token seamlessly to configured applications as single sign-on.

Conversely, single sign-off is the property whereby a single action of signing out terminates access to multiple software systems.

As different applications and resources support different authentication mechanisms, single sign-on must internally store the credentials used for initial authentication and translate them to the credentials required for the different mechanisms.

2.5 Kerberos

Kerberos is an authentication protocol for trusted hosts on untrusted networks. It is a protocol designed to provide reliable authentication over open and insecure networks where communications between the hosts belonging to it may be intercepted.

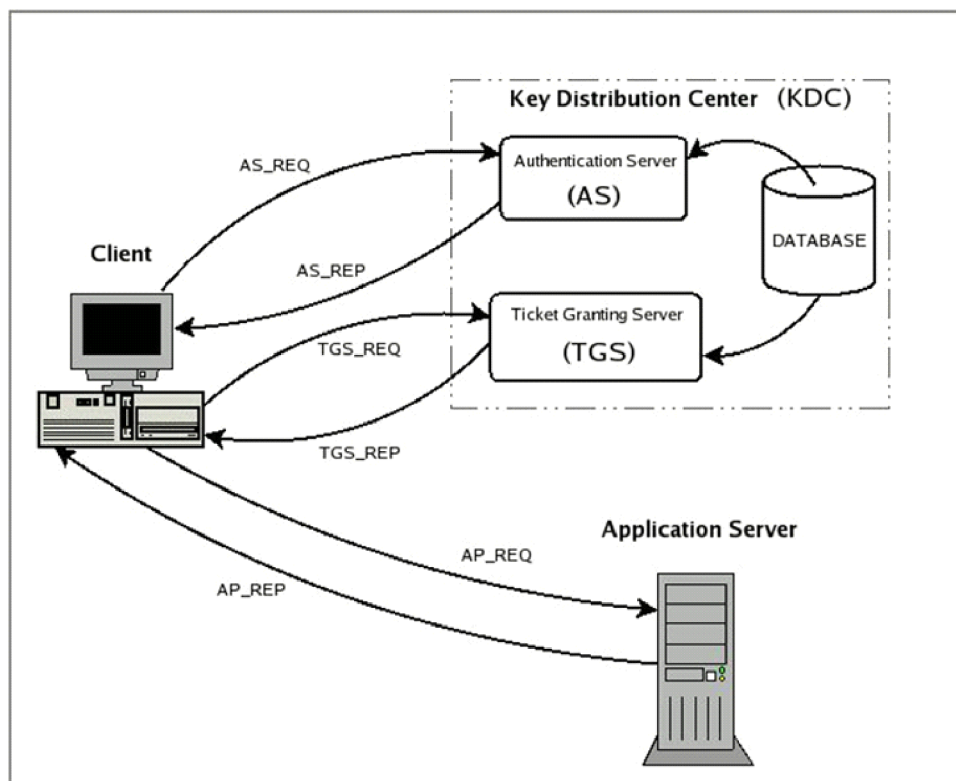


Figure: 2.5: Kerberos system

Database: The database is the container for entries associated with users and services. We refer to an entry by using the principal (i.e. the name of the entry) even if often the term principal is used as a synonym for entry.

Authentication Server (AS): The Authentication Server is the part of the KDC which replies to the initial authentication request from the client, when the user, not yet authenticated, must enter the password. In response to an authentication request, the AS issues a special ticket known as the Ticket Granting Ticket.

Ticket Granting Server (TGS): The Ticket Granting Server is the KDC component which distributes service tickets to clients with a valid TGT, guaranteeing the authenticity of the identity for obtaining the requested resource on the application servers.

- **AS_REQ** is the initial user authentication request (i.e. made with kinit) This message is directed to the KDC component known as Authentication Server (AS).
- **AS_REP** is the reply of the Authentication Server to the previous request. Basically, it contains the TGT (encrypted using the TGS secret key) and the session key (encrypted using the secret key of the requesting user).
- **TGS_REQ** is the request from the client to the Ticket Granting Server (TGS) for a service ticket. This packet includes the TGT obtained from the previous message and an authenticator generated by the client and encrypted with the session key.
- **TGS_REP** is the reply of the Ticket Granting Server to the previous request. Located inside is the requested service ticket (encrypted with the secret key of the service) and a service session key generated by TGS and encrypted using the previous session key generated by the AS.
- **AP_REQ** is the request that the client sends to an application server to access a service. The components are the service ticket obtained from TGS with the previous reply and an authenticator again generated by the client, but this time encrypted using the service session key (generated by TGS).
- **AP_REP** is the reply that the application server gives to the client to prove it really is the server the client is expecting. This packet is not always requested. The client requests the server for it only when mutual authentication is necessary.

2.6 Sesame

SESAME (a Secure European System for Applications in a Multi-vendor Environment) is a European research and development project, part funded by the European Commission under its RACE programme. It is also the name of the technology that came out of that project.

The SESAME technology offers sophisticated single sign-on with added distributed access control features and cryptographic protection of interchanged data.

SESAME is a construction kit. It is a set of security infrastructure components for product developers. It provides the underlying bedrock upon which full managed single sign-on products can be built.

Working of Sesame

To access the distributed system, a user first authenticates to an Authentication Server to get a cryptographically protected token used to prove his or her identity. The user then presents the token to a Privilege Attribute Server to obtain a guaranteed set of access rights contained in a Privilege Attribute Certificate (or PAC). The PAC is a specific form of Access Control Certificate that conforms to ECMA and ISO/ITU-T standards.

The promulgation, protection and use of PACs are central features of the SESAME design.

The PAC is presented by the user to a target application whenever access to a protected resource is needed. The target application makes an access control decision according to the user's security attributes from the PAC, and other access control information (for example an Access Control List) attached to the controlled resource.

A PAC can be used more than once at more than one target application. It is digitally signed to prevent it being undetectably tampered with.

In some circumstances a user might want an application to act on his or her behalf. The user might want to delegate access rights to that application. SESAME supports delegation, allowing this to be controlled by the user, who can dictate which applications are permitted to act as delegates, and which other applications they can access on the user's behalf.

The PAC is cryptographically protected from the point it leaves the Privilege Attribute Server all the way to the final target application to prevent anybody but its genuine owner or an authorized delegate making use of it.

To provide this protection SESAME needs to establish temporary secret cryptographic keys shared pairwise between the participants. Kerberos key distribution protocols can be used for this, but they can also be either supplemented, or where appropriate completely replaced by public key technology. SESAME also supports Certification Authorities, X.509 Directory user certificates, following ISO/ITU-T standards.

User data passed in a dialogue between a client and a server can optionally be either integrity protected or confidentiality protected or both, using specially created Dialogue Keys.

Dialogue Keys also ensure that the actions that are authorised really have come from the user whose PAC is providing the basis for that authorization.

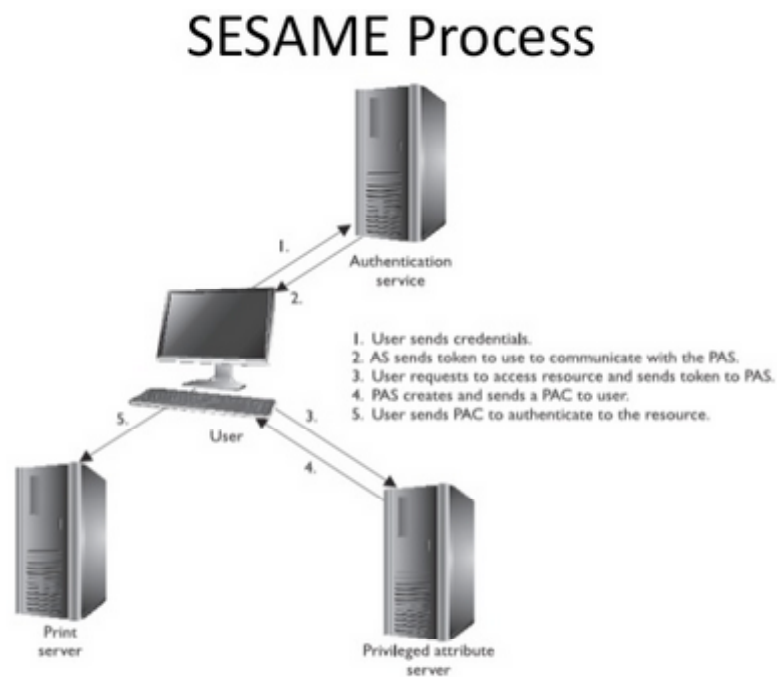


Figure 2.6: SESAME Process

2.7 Authentication in Wireless Networks

Authentication types are tied to the Service Set Identifiers (SSIDs) that are configured for the access point. For different types of client devices with the same access point, multiple SSIDs need to be configured.

Before a wireless client device can communicate on the network through its access point, it must authenticate to the access point by using open or shared-key authentication. For maximum security, client devices should also authenticate to the network using MAC-address or Extensible Authentication Protocol (EAP) authentication. Both of these authentication types rely on an authentication server on the network.

The access point uses several authentication mechanisms or types and can use more than one at the same time. These sections explain each authentication type:

- **Open Authentication to the Access Point:** Open authentication allows any device to authenticate and then attempt to communicate with the access point. Using open authentication, any wireless device can authenticate with the access point, but the device can communicate only if its Wired Equivalent Privacy (WEP) keys match the access point's WEP keys. Devices that are not using WEP do not attempt to authenticate with an access point that is using WEP. Open authentication does not rely on a RADIUS server on your network.
- **Shared Key Authentication to the Access Point:** During shared key authentication, the access point sends an unencrypted challenge text string to any device that is attempting to communicate with the access point. The device that is requesting authentication encrypts the challenge text and sends it back to the access point. If the challenge text is encrypted correctly, the access point allows the requesting device to authenticate.
- **EAP Authentication to the Network:** This authentication type provides the highest level of security for your wireless network. By using the Extensible Authentication Protocol (EAP) to interact with an EAP-compatible RADIUS server, the access point helps a wireless client device and the RADIUS server to perform mutual authentication and derive a dynamic unicast WEP key. The RADIUS server sends the WEP key to the access point, which uses the key for all unicast data signals that the server sends to or receives from the client.
- **MAC Address Authentication to the Network:** The access point relays the wireless client device's MAC address to a RADIUS server on your network, and the server checks the address against a list of allowed MAC addresses. Because intruders can create counterfeit MAC addresses, MAC-based authentication is less secure than EAP authentication. However, MAC-based authentication provides an alternate authentication method for client devices that do not have EAP capability.

- **Combining MAC-Based, EAP, and Open Authentication:** The access point can be set up to authenticate client devices that use a combination of MAC-based and EAP authentication. When this feature is enabled, client devices that use 802.11 open authentication to associate to the access point first attempt MAC authentication. If MAC authentication succeeds, the client device joins the network.
- **Using CCKM for Authenticated Clients:** Using Cisco Centralized Key Management (CCKM), authenticated client devices can roam from one access point to another without any perceptible delay during reassociation. An access point on your network provides Wireless Domain Services (WDS) and creates a cache of security credentials for CCKM-enabled client devices on the subnet.
- **Using WPA Key Management:** Wi-Fi Protected Access (WPA) is a standards-based, interoperable security enhancement that strongly increases the level of data protection and access control for existing and future wireless LAN systems. It is derived from and will be forward-compatible with the upcoming IEEE 802.11i standard. WPA leverages TKIP (Temporal Key Integrity Protocol) for data protection and 802.1X for authenticated key management.

Summary

- Authentication is used by a server when the server needs to know exactly who is accessing their information or site.
- PAP is a simple user authentication protocol. It does not encrypt the data and sends the password and username in clear text.
- CHAP provides protection against replay attacks by the peer through the use of an incrementally changing identifier and of a variable challenge-value.
- Radius is a protocol for carrying information related to authentication, authorization, and configuration between a Network Access Server (NAS) that desires to authenticate its links and a shared Authentication Server.
- TACACS (Terminal Access Controller Access Control System) is an older authentication protocol common to UNIX networks that allows a remote access server to forward a user's logon password to an authentication server to determine whether access can be allowed to a given system.
- Single sign-on (SSO) is a property of access control of multiple related, yet independent, software systems.

- Kerberos is an authentication protocol for trusted hosts on untrusted networks. It is a protocol designed to provide reliable authentication over open and insecure networks where communications between the hosts belonging to it may be intercepted.
- The SESAME technology offers sophisticated single sign-on with added distributed access control features and cryptographic protection of interchanged data.

Check your Answers

- 1) What are the various authentication types in wireless networks?
- 2) Differentiate between RADIUS and TACACS.
- 3) Write short notes on: PAP and CHAP.
- 4) Explain briefly the working of SEASME.
- 5) Explain briefly about Kerberos.

References

- <https://www.bu.edu/tech/about/security-resources/bestpractice/auth/>
- https://www.cosic.esat.kuleuven.be/sesame/html/sesame_what.html
- https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-chap/8fea1dd1-66d6-4874-88a5-34bcd5b58907
- <https://www.cisco.com/c/en/us/td/docs/routers/access/wireless/software/guide/SecurityAuthenticationTypes.html#wp1002608>

Lesson – 3

Real World Protocols

Learning Objectives

After reading this lesson you will be able to understanding the following:

- Introduction to IP Sec
- IP Sec Building Blocks
- Security Association (SAs)
- Security Parameter Index (SPI)
- IP Sec Architecture
- IP Sec Protocols (AH and ESP)
- Tunneling and Transport Mode
- Internet Key Exchange (IKE) – ISAKMP
- TLS and SSL

Structure

- 3.1 Introduction to IPSEC**
- 3.2 IPSEC Building blocks**
- 3.3 Security Associations**
- 3.4 Security Parameter Index**
- 3.5 IPSEC Architecture**
- 3.6 Tunneling Mode & Transport Mode**
- 3.7 Internet Key Exchange**
- 3.8 TLS Vs. SSL**

3.1 Introduction to IPSEC

- IPsec stands for IP Security
- This is a standard architecture set forth by the Internet Engineering Task Force (IETF) for setting up a secure channel to exchange information between two entities.

- The entities communicating via IPsec could be two systems, two routers, two gateways, or any combination of entities.
- IPsec uses cryptography to provide encryption, access control, non repudiation, and message authentication, all using IP-based protocols.
- The primary use of IPsec is for virtual private networks (VPNs), so IPsec can operate in either transport or tunnel mode.

IPsec AH and ESH

Authentication Header (AH) and Encapsulating Security Payload (ESP) are the two main wire-level protocols used by IPsec. They authenticate (AH) and encrypt-plus-authenticate (ESP) the data flowing over that connection.

AH: is used to authenticate—but not encrypt—IP traffic. Authentication is performed computing a cryptographic hash-based message authentication code over nearly all the fields of the IP packet (excluding those which might be modified in transit, such as TTL or the header checksum), and stores this in a newly-added AH header that is sent to the other end. This AH header is injected between the original IP header and the payload.

ESP: provides encryption and optional authentication. It includes header and trailer fields to support the encryption and optional authentication. Encryption for the IP payload is supported in transport mode and for the entire packet in the tunnel mode. Authentication applies to the ESP header and the encrypted data.

3.2 IPsec Building Blocks

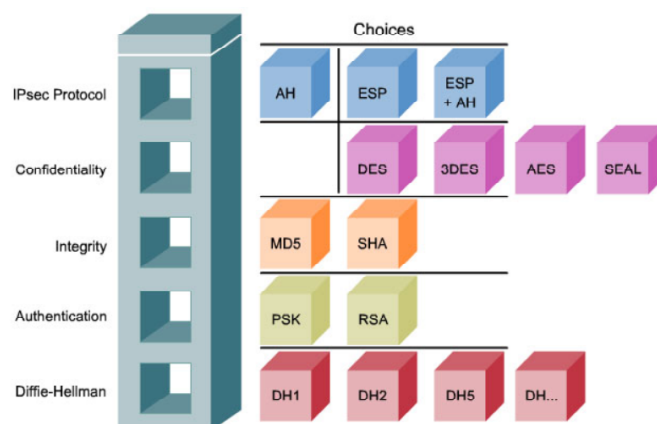


Fig 3.1: IP Sec Building Blocks

- First represents the IPsec protocol. Choices include ESP or AH.
- Second represents the type of confidentiality implemented using an encryption algorithm such as DES, 3DES, AES or SEAL. The choice depends on the level of security required.
- Third represents integrity that can be implemented using MD5 or SHA.
- Fourth represents how the shared secret key is established. The two methods are Pre-shared, Digitally Signed Using RSA.
- Fifth represents the DH[Diffie-Hellman] algorithm group. There are four separate DH key exchange algorithms
 - DH Group 1(DH1)- 768-bit
 - DH Group 2(DH2)- 1024-bit
 - DH Group 5(DH5)- 1536-bit
 - DH Group 7(DH7)- 2048-bit

3.3 Security Associations (SAs)

A security association (SA) is a logical connection involving two devices that transfer data. With the help of the defined IPsec protocols, SAs offer data protection for unidirectional traffic. Generally, an IPsec tunnel features two unidirectional SAs, which offer a secure, full-duplex channel for data.

A security association consists of features like traffic encryption key, cryptographic algorithm and mode, and also parameters required for the network data.

The Internet Security Association and Key Management Protocol (ISAKMP) provides the framework for establishing SAs, whereas the authenticated keying material is offered by protocols like Internet Key Exchange (IKE) and Kerberized Internet Negotiation of Keys (KINK).

With SAs, enterprises can manage specifically which resources can securely communicate as per the security policy. In order to execute this, enterprises can put together several SAs to facilitate various secure VPNs in addition to defining the SAs inside the VPN for supporting many different units as well as business partners.

Security associations use modes for their operation. A mode is a method wherein the IPsec protocol is applied to the packet. IPsec is used in transport or tunnel mode. In general, the transport mode is employed to protect the host-to-host IPsec tunnel, whereas the tunnel mode is implemented to protect the gateway-to-gateway IPsec tunnel.

In transport mode the payload of the packet is encapsulated by the transport-mode IPsec implementation; however, the IP header remains unchanged. The new IP packet includes the processed packet payload as well as the old IP header once the packet is processed with IPsec. The transport mode does not have the capability to shield the information carried in the IP header, which lets an attacker identify the source and destination of the packet.

In tunnel mode the IPsec implementation encapsulates the whole IP packet. The whole packet turns into the packet's payload that is processed using IPsec. The newly created IP header contains two IPsec gateway addresses. Use of the tunnel mode prevents an attacker from inspecting the information and decoding it, and it also hides the source and destination of the packet.

3.4 Security Parameter Index (SPI)

The Security Parameter Index (SPI) is an identification tag added to the header while using IPsec for tunneling the IP traffic. This tag helps the kernel discern between two traffic streams where different encryption rules and algorithms may be in use.

The SPI (as per RFC 2401) is a required part of an IPsec Security Association (SA) because it enables the receiving system to select the SA under which a received packet will be processed. An SPI has only local significance, since it is defined by the creator of the SA; an SPI is generally viewed as an opaque bit string. However, the creator of an SA may interpret the bits in an SPI to facilitate local processing.

This works like port numbers in TCP and UDP connections. What it means is that there could be different SAs used to provide security to one connection. An SA could therefore act as a set of rules.

Carried in Encapsulating Security Payload (ESP) header or Authentication Header (AH), its length is 32 bits.

3.5 IPsec Architecture

- IPsec relies on Security Associations (SAs), and there are two main components:
 1. The Authentication Header (AH)
 2. The Encapsulating Security Payload (ESP)
- AH provides Authentication and Data Integrity
- ESP provides Authentication, Data Integrity and Confidentiality

3.5.1 AH and ESP

- IPsec protocols AH and ESP can be used in two different ways or “modes”
- Transport mode: to protect only the upper-layer protocols of an IP payload.
- IPsec is used between the IP header and the upper-layer protocol payload.
- Tunnel mode: to protect the entire IP payload.
- IPsec encapsulates the whole IP packet and a new IP header is created to transmit the packet.

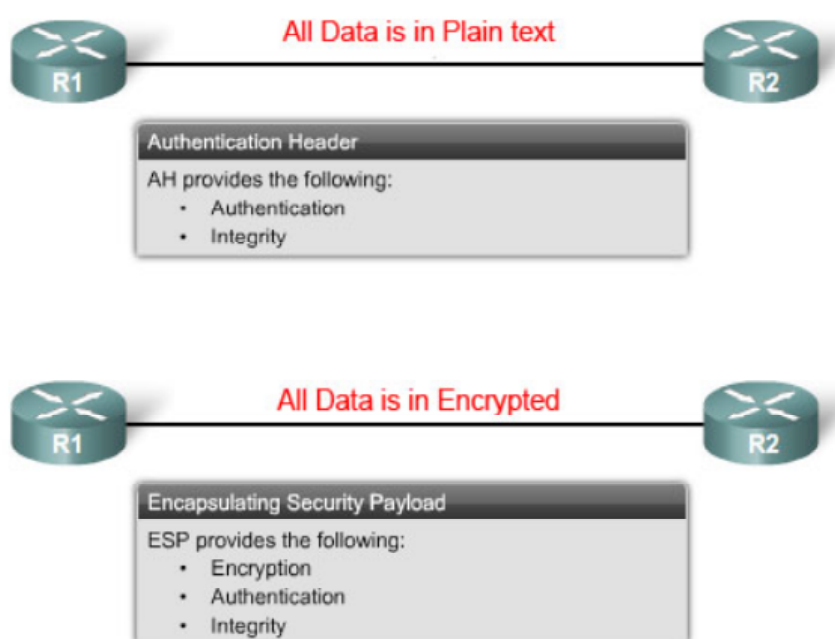


Fig 3.2: AH and ESP

3.5.2 ESP Trailer

- ESP trailer: Padding (optional): to ensure that the data will be of the correct length for particular types of encryption
- Padding length: total number of bytes of padding
- Next header: TCP/UDP or ICMP
- Authentication data: either MD5 or SHA

3.6 Tunneling Mode & Transport Mode

IPsec has two modes of operations. Transport mode and Tunnel mode.

- In transport mode, only the packet payload is encrypted.
- Under the Tunnel mode, the entire packet, including the header, is encrypted (For gateway-to gateway communication).

ESP contains a header not encrypted and a trailer that is partially encrypted.

Encapsulating Security Payload

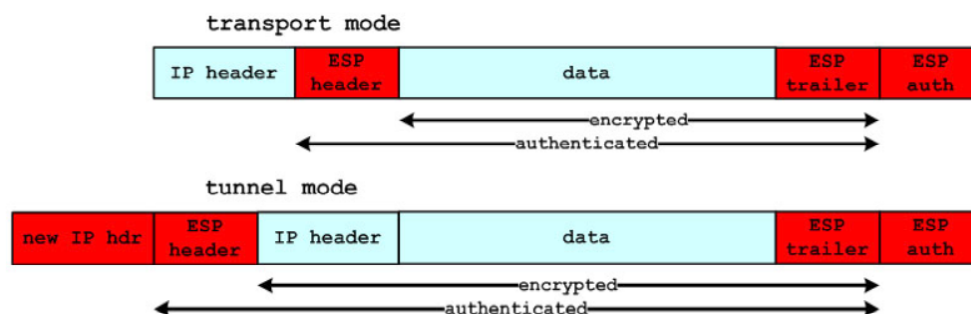


Fig 3.3: ESP – Tunnel and Transport Mode

3.7 INTERNET KEY EXCHANGE(IKE)-ISAKMP

Before IPsec sends authenticated or encrypted IP data, both the sender and receiver must agree on the protocols, encryption algorithms and keys to use for message integrity, authentication and encryption. IKE is used to negotiate these and provides primary authentication. Key lifetimes can be set and re-keying can be done automatically.

IKE is a hybrid of the ISAKMP, Oakley and Secure Key Exchange Mechanics SKEME protocols. ISAKMP provides a framework for authentication and key exchange but does not define them. It is designed to be key exchange independent; that is, it is designed to support many different key exchanges.

Oakley describes a series of key exchanges, known as modes, and details the services provided by each (e.g. perfect forward secrecy for keys, identity protection, and authentication). SKEME describes a versatile key exchange technique which provides anonymity, repudiability, and quick key refreshment. Perfect Forward Secrecy is supported. IKEv2 does not interoperate with IKEv1, but it has enough of the header format in common that both versions can unambiguously run over the same UDP port.

RFC 2409: Oakley and SKEME each define a method to establish an authenticated key exchange. This includes payloads construction, the information payloads carry, the order in which they are processed and how they are used. While Oakley defines “modes”, ISAKMP defines “phases”. The relationship between the two is very straightforward and IKE presents different exchanges as modes which operate in one of two phases.

Phase 1 is where the two ISAKMP peers establish a secure, authenticated channel with which to communicate. This is called the ISAKMP Security Association (SA). “Main Mode” and “Aggressive Mode” each accomplish a phase 1 exchange. “Main Mode” and “Aggressive Mode” MUST ONLY be used in phase 1.

Phase 2 is where Security Associations are negotiated on behalf of services such as IPsec or any other service which needs key material and/or parameter negotiation. “Quick Mode” accomplishes a phase 2 exchange. “Quick Mode” MUST ONLY be used in phase 2.

3.8 TLS and SSL

3.8.1 TLS (TRANSPORT LAYER SECURITY)

TLS is a cryptographic protocol that provides end-to-end communications security over networks and is widely used for internet communications and online transactions. It is an IETF standard intended to prevent eavesdropping, tampering and message forgery. Common applications that employ TLS include Web browsers, instant messaging, e-mail and voice over IP.

Many businesses use TLS to secure all communications between their Web servers and browsers regardless of whether sensitive data is being transmitted.

TLS's predecessor, secure socket layer (SSL) was developed by Netscape in 1995. SSL version 1.0 and 2.0 contained many security flaws that prompted a complete redesign of the protocol. In 1996, Netscape released SSL version 3.0 which was the basis for TLS1.0. In 1999, the PCI Council suggested the eventual deprecation of SSL as TLS 1.0 was a significant upgrade to SSL 3.0

CoAP : constrained Application Protocol is a specialized internet Application protocol for constrained devices.

DLTs: Datagram Transport Layer Security. Datagram TLS is a communication protocols that provides security for datagram - based application by allowing them to communicate in a way that is designed to prevent eaves dropping, tampering or message forgery.

CoAP + DTLs



Fig 3.4: TLS Communication

3.8.2 SSL (Secured Socket Layer)

Technically, SSL is a transparent protocol which requires little interaction from the end user when establishing a secure session. In the case of a browser for instance, users are

alerted to the presence of SSL when the browser displays a padlock, or, in the case of Extended Validation SSL, when the address bar displays both a padlock and a green bar. This is the key to the success of SSL – it is an incredibly simple experience for end users.

3.8.3 TLS vs. SSL

TLS is more efficient and secure than SSL as it has stronger message authentication, key-material generation and other encryption algorithms. For example, TLS supports pre-shared keys, secure remote passwords, elliptical-curve keys and Kerberos whereas SSL does not. TLS and SSL are not interoperable, but TLS does offer backward compatibility for older devices still using SSL.

The TLS protocol specification defines two layers. The TLS record protocol provides connection security, and the TLS handshake protocol enables the client and server to authenticate each other and to negotiate security keys before any data is transmitted.

The TLS handshake is a multi-step process. A basic TLS handshake involves the client and server sending “hello” messages, and the exchange of keys, cipher message and a finish message. The multi-step process is what makes TLS flexible enough to use in different applications because the format and order of exchange can be modified.

The confusion around SSL and TLS comes from backwards compatibility. TLS 1.2 has remnants of earlier versions of SSL to make it compatible with outdated browsers. As such, many websites haven’t disabled the features that make a protocol such as TLS 1.2 unsecure.

That’s where TLS 1.3 comes in. It’s built to disable legacy features and speed up performance on a secure connection. Instead of agreeing on an encryption model, the server provides the encryption key with TLS 1.3. That, theoretically, makes the multiple downgrade attacks, which force the server to use an older protocol, obsolete.

The latest update is a push toward the modern internet, abandoning the outdated model established by early versions of SSL. Hopefully, within a few years, attacks like POODLE won’t be as much of a concern as they are today.

Summary

- IPsec uses cryptography to provide encryption, access control, nonrepudiation, and message authentication, all using IP-based protocols.

- The primary use of IPsec is for virtual private networks (VPNs), so IPsec can operate in either transport or tunnel mode.
- A security association (SA) is a logical connection involving two devices that transfer data.
- The Security Parameter Index (SPI) is an identification tag added to the header while using IPsec for tunneling the IP traffic. This tag helps the kernel discern between two traffic streams where different encryption rules and algorithms may be in use.
- In transport mode, only the packet payload is encrypted.
- Under the Tunnel mode, the entire packet, including the header, is encrypted (For gateway-to gateway communication).
- IKE is a hybrid of the ISAKMP, Oakley and SKEME protocols.
- SSL is a transparent protocol which requires little interaction from the end user when establishing a secure session.
- TLS is more efficient and secure than SSL as it has stronger message authentication, key-material generation and other encryption algorithms.

Check your Answers

- 1) Write short notes on: AH, ESP.
- 2) Differentiate between SSL and TLS.
- 3) What do you understand by Security Parameter Index (SPI).
- 4) What is the latest version of TLS in use?
- 5) What is encrypted inside the tunnel mode?

References:

- https://www.cisco.com/c/en/us/td/docs/wireless/asr_5000/20/IPSec/b_20_IPSec/b_20_IPSec_chapter_01.pdf
- <https://www.cloudwards.net/ssl-vs-tls/>

Lesson – 4

Virtual Private Networks

Learning Objectives

After reading this lesson you will be able to understanding the following:

- VPN and its types
- Tunneling Protocols
- Tunnel and Transport Mode
- Generic Routing Encapsulation (GRE)

Structure

- 4.1 Understanding VPN & its working**
- 4.2 VPN Tunneling Protocol**
- 4.3 Tunneling Mode & Transport Mode**
- 4.4 Generic Routing Encapsulation**

4.1 Understanding Virtual Private Network (VPN) and its Working

- A virtual private network (VPN) is a communication tunnel that provides point-to-point transmission of both authentication and data traffic over an intermediary untrusted network.
- Most VPNs use encryption to protect the encapsulated traffic, but encryption is not necessary for the connection to be considered a VPN.
- Information traveling between a connected device (computer, smartphone, tablet) and a VPN server is encrypted, and as a result, any applications running on the VPN network benefit from the security, functionality, and strength of the private network.
- Connecting to a Virtual Private Network often conceals the real IP address and allots a new one.

4.2 VPN Tunneling Protocol

VPN links are encrypted to add privacy, confidentiality, and authentication and to maintain data integrity.

Protocols used to establish VPNs are

- Point-to-Point Tunnelling Protocol (PPTP)
- Layer 2 Tunnelling Protocol (L2TP)
- Secure Shell (SSH)
- OpenVPN (SSL/TLS VPNs), and
Internet Protocol Security (IPSec)

4.2.1 PPTP

- Point-to-Point Tunnelling Protocol (PPTP) is an encapsulation protocol developed from the dial-up Point-to-Point Protocol.
- It operates at the Data Link layer (layer 2) of the OSI model and is used on IP networks.
- PPTP creates a point-to-point tunnel between two systems and encapsulates PPP packets.
- It offers protection for authentication traffic through the same authentication protocols supported by PPP.

4.2.2 L2TP

- Layer 2 Tunnelling Protocol (L2TP) was derived by combining elements from both PPTP and L2F. L2TP creates a point-to-point tunnel between communication endpoints.
- It lacks a built-in encryption scheme, but it typically relies on IPsec as its security mechanism.
- L2TP also supports TACACS+ and RADIUS. IPsec is commonly used as a security mechanism for L2TP.

4.2.3 L2F

- Cisco developed its own VPN protocol called Layer 2 Forwarding (L2F), which is a mutual authentication tunnelling mechanism.
- However, L2F does not offer encryption. L2F was not widely deployed and was soon replaced by L2TP

4.2.4 SITE TO SITE VPN

- Remote access servers or firewalls on the network's border act as the start points and endpoints for VPNs.
- Thus, traffic is unprotected within the source LAN, protected between the border VPN servers, and then unprotected again once it reaches the destination LAN.

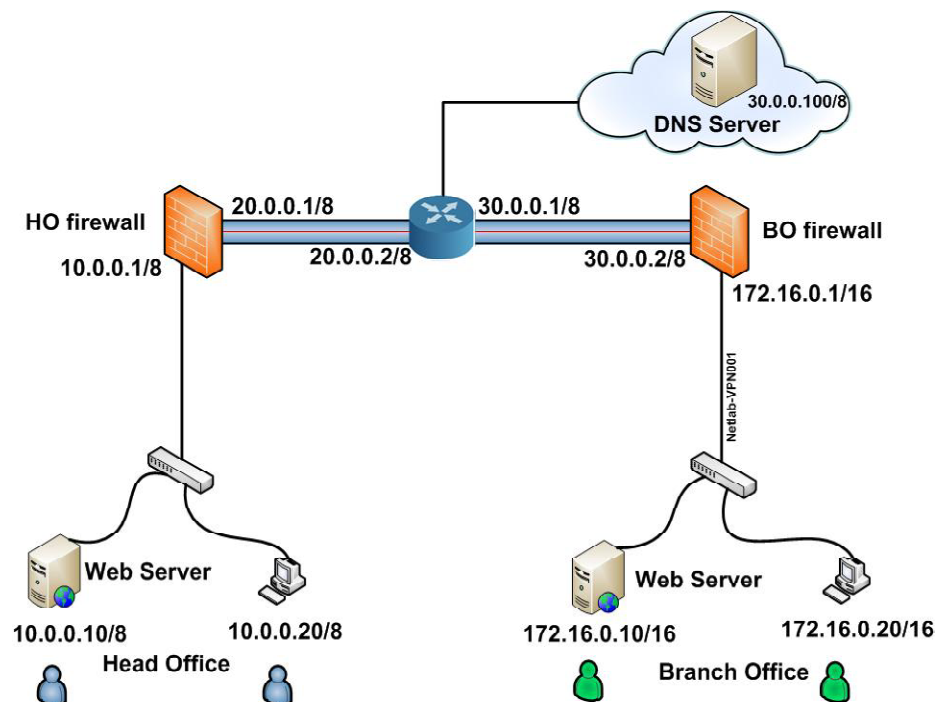


Fig 4.1: Site-to-Site VPN

4.2.5 Remote Access VPN

A remote-access VPN allows individual users to establish secure connections with a remote computer network. Those users can access the secure resources on that network as if they were directly plugged in to the network's servers. An example of a company that needs a

remote-access VPN is a large firm with hundreds of salespeople in the field. Another name for this type of VPN is virtual private dial-up network (VPDN), acknowledging that in its earliest form, a remote-access VPN required dialing in to a server using an analog telephone system.

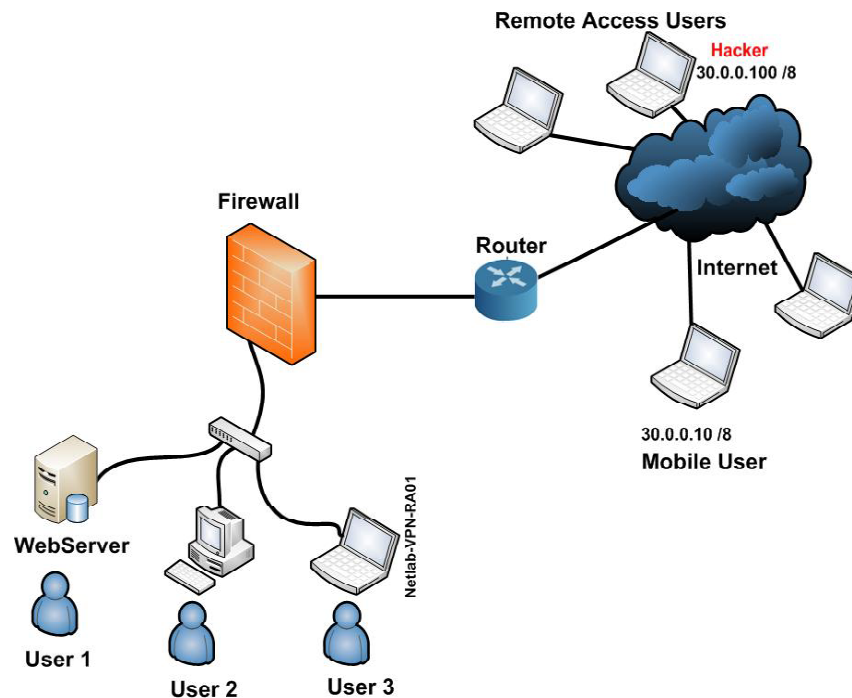


Fig 4.2: REMOTE ACCESS VPN

4.3 Tunneling Mode & Transport Mode

IPsec has two modes of operations. Transport mode and Tunnel mode.

- In transport mode, only the packet payload is encrypted.
- Under the Tunnel mode, the entire packet, including the header, is encrypted (For gateway-to-gateway communication).

ESP contains a header not encrypted and a trailer that is partially encrypted.

Encapsulating Security Payload

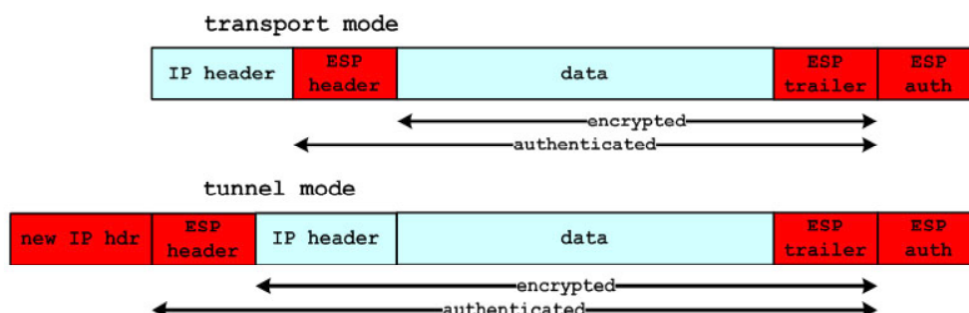


Fig 3.3: ESP – Tunnel and Transport Mode

4.3.1 AH and ESP

- IPSec protocols AH and ESP can be used in two different ways or “modes”
- Transport mode: to protect only the upper-layer protocols of an IP payload.
- IPSec is used between the IP header and the upper-layer protocol payload.
- Tunnel mode: to protect the entire IP payload.
- IPSec encapsulates the whole IP packet and a new IP header is created to transmit the packet.

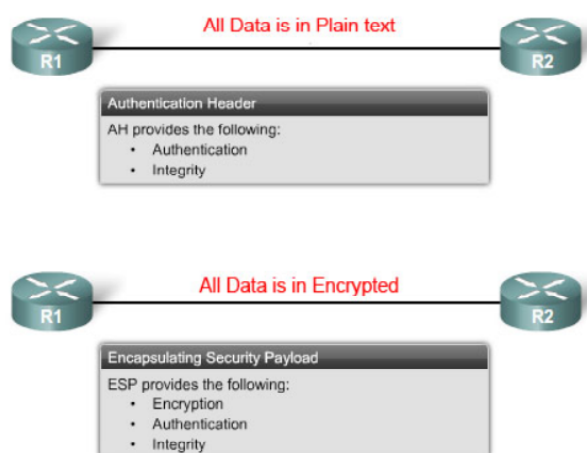


Fig 3.4: AH and ESP

4.3.2 ESP Trailer

- ESP trailer: Padding (optional): to ensure that the data will be of the correct length for particular types of encryption
- Padding length: total number of bytes of padding
- Next header: TCP/UDP or ICMP
- Authentication data: either MD5 or SHA

4.4 Generic Routing Encapsulation (GRE)

- Generic Routing Encapsulation (GRE) is a tunnelling protocol developed by Cisco Systems that can encapsulate a wide variety of network layer protocols inside virtual point-to-point links or point-to-multipoint links over an Internet Protocol network.
- GRE works by encapsulating a payload — that is, an inner packet that needs to be delivered to a destination network — inside an outer IP packet.
- GRE tunnel endpoints send payloads through GRE tunnels by routing encapsulated packets through intervening IP networks.
- Other IP routers along the way do not parse the payload (the inner packet); they only parse the outer IP packet as they forward it towards the GRE tunnel endpoint.
- Upon reaching the tunnel endpoint, GRE encapsulation is removed and the payload is forwarded along to its ultimate destination.

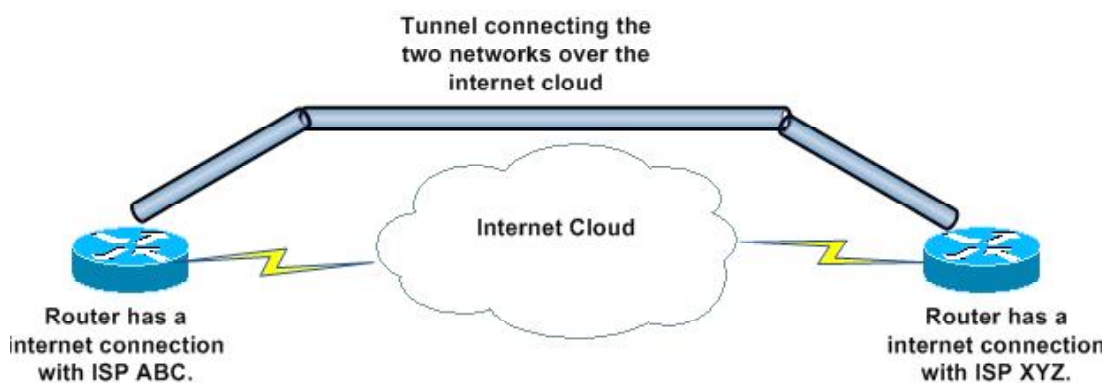


Figure: GRE Tunneling

Summary

- A virtual private network (VPN) is a communication tunnel that provides point-to-point transmission of both authentication and data traffic over an intermediary untrusted network.
- Point-to-Point Tunnelling Protocol (PPTP) is an encapsulation protocol developed from the dial-up Point-to-Point Protocol.
- Layer 2 Tunnelling Protocol (L2TP) was derived by combining elements from both PPTP and L2F. L2TP creates a point-to-point tunnel between communication endpoints.
- Cisco developed its own VPN protocol called Layer 2 Forwarding (L2F), which is a mutual authentication tunnelling mechanism.
- Remote access servers or firewalls on the network's border act as the start points and endpoints for VPNs.
- A remote-access VPN allows individual users to establish secure connections with a remote computer network.
- GRE works by encapsulating a payload — that is, an inner packet that needs to be delivered to a destination network — inside an outer IP packet.

Check your Answers

- 1) What are the benefits of using a VPN?
- 2) List the types of VPN.
- 3) Write short notes on VPN Tunneling Protocols.
- 4) Short notes on GRE.

Reference

- https://en.wikipedia.org/wiki/Virtual_private_network
- <https://computer.howstuffworks.com/three-types-of-vpn.htm>
- <https://www.vpnoneclick.com/types-of-vpn-and-types-of-vpn-protocols/>
- https://www.cisco.com/c/en/us/td/docs/cable/cbr/configuration/guide/b_cbr_layer2_docsis/generic_routing_encapsulation.pdf

Lesson – 5

MPLS and MPLS VPN

Learning Objectives

After reading this lesson you will be able to understanding the following:

- WAN Topologies
- Standard IP based Switching
- CEF based Multi-Layer Switching
- MPLS Characteristics
- Frame Mode MPLS Operation
- MPLS VPN

Structure

- 5.1 WAN Topologies**
- 5.2 Standard IP based Switching**
- 5.3 CEF based MLS**
- 5.5 MPLS**
- 5.5 Frame Mode MPLS Operation**
- 5.6 MPLS VPN**

5.1 WAN Topologies

Wide area networks, or WANs, provide network communication services in the workplace, connecting locations that can be spread out anywhere in the world. A topology is a description of a layout or arrangement. Applying the concept of topologies to WANs involves two different but interrelated perspectives. One perspective to consider is the physical topology, which describes the physical arrangement of network devices that allow for data to move from a source to a destination network. Another perspective is the logical topology, which describes how data moves over the WAN.

Types of Network Topologies

Bus Network Topology

The Bus topology within the WAN environment often covers small geographical areas i.e. within the same country. The Bus topology is characterized by the hard cabling (commonly called backbone) in which the different sites on the network are connected by high capacity network cabling. In this orientation each site is connect in a line with the other sites via the backbone. With the exception of the sites at the end, each site is connected to another directly before and after it. This is illustrated in Figure 3.

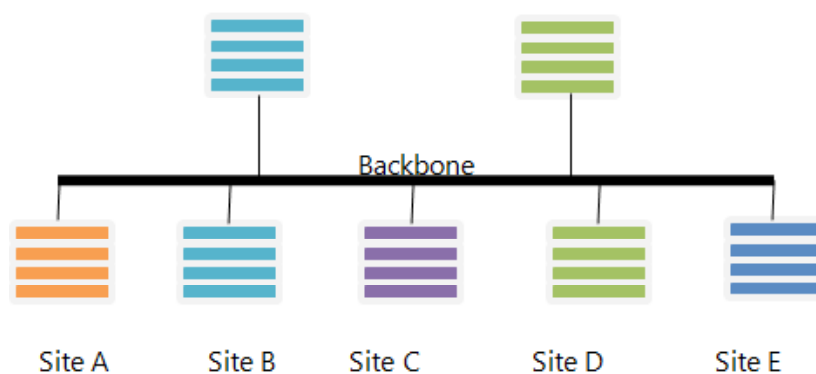


Fig 5.1: WAN Bus Topology

Communication

In this Bus topology, if a site wishes to communicate with another site, it broadcasts a message on the backbone, which is accessible and seen by all connected sites. The recipient, however, will be the only one to retrieve the message.

Advantages

It is cost effective and simple to implement. There is comparatively minimal cabling with each site connected by a single cable.

Disadvantages

There is complete network failure in the event that one of the site cables fail. An increase in the number of nodes increases the traffic on the backbone reducing network efficiency.

Ring Network Topology

As the name suggests the Ring topology orientation has sites arranged in a ring. This is very similar to the Bus topology discussed earlier. The main difference being there are no sites at the end. Each site is connected to each other as seen in Figure 4 with the last and first sites connected completing the ring.

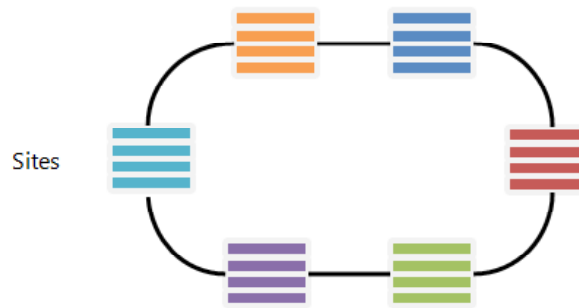


Fig 5.2: Ring Topology

Communication

Network traffic can be routed in both directions. This makes this topology less vulnerable than the Bus topology. If a line connection fails traffic is rerouted in the opposite direction and communication is not lost. Repeaters are also used to maintain network integrity and prevent data loss, when there are a high number of sites. This is because for n number of sites data will have to traverse n nodes until it gets to the desired destination increasing the likelihood of data loss.

Advantages

- Data transmission is unidirectional.
- Cheap to install and easy to add on nodes.

Disadvantages

- Troubleshooting issues can be difficult and adding/removing nodes can cause network disruptions.

Star Network Topology

With the Star topology, the sites are arranged in a star formation. There is a central hub and each site is connected directly to the hub.



Fig 5.3: Star Topology

Communication

In this topology the central hub is known as concentration router which ensures that transmission reaches the correct destinations at all times. A failure is a site connection that does not affect other parts of the network.

Advantages

- Adding and removing nodes is easy and the network is more robust, with the orientation preventing data collision between sites.

Disadvantages

- It requires more hardware.
- The entire networks operation and efficiency depends entirely on the hub. If the hub fails for any reason the whole network goes down.

Mesh Network Topology

In the Mesh topology every device belonging to the network is connected to every other device in a mesh formation. This is quite different from the previous topologies where sites are connected to a maximum of two sites at a time.



Fig 5.4 Mesh Topology

5.2 Standard IP based Switching

This technology has been developed by Ipsilon Networks Inc. The goal of Ipsilon is to make IP faster and offer the quality of service support. The “IP over ATM” approach tries to hide the underlying network topology from IP layer by treating the data link layer as large, opaque network cloud. However, this leads to inefficiency, complexity and duplication of functionality in the resulting network [ATM under IP]. Ipsilon’s approach is to discard the connection-oriented ATM software and implement the connectionless IP routing directly on the top of ATM hardware. This approach takes the advantage of robustness and scalability of connectionless IP and speed, capacity and scalability of ATM switches.

IP Switch

IP switch ([ATM under IP]) is basically an IP router with attached switching hardware that has the ability to cache routing decisions in switching hardware. To construct an IP switch, a standard ATM switch is taken, the hardware is left untouched, but all the control software above AAL-5 is removed. It is replaced by standard IP routing software, a flow classifier to decide whether to switch a flow or not and a driver to control the switch hardware. At system startup a default virtual channel is established between the control software of the IP switch and its neighbors, which is then used for default hop-by-hop forwarding of IP datagrams. To gain the benefits of switching, a mechanism has been defined to associate IP flows with the ATM labels.

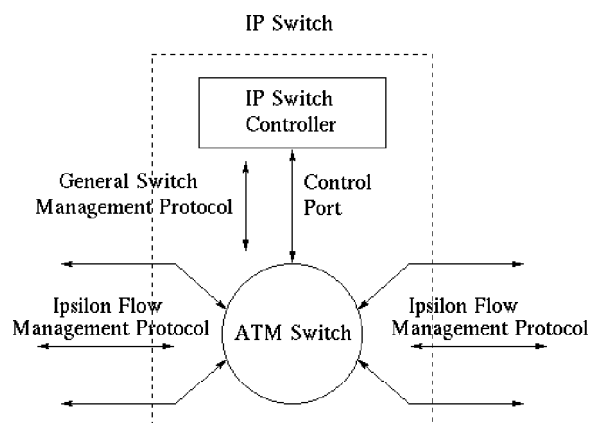


Figure 1: Structure of An IP Switch

Fig 5.5: Structure of an IP Switch

5.3 Cisco Express Forwarding (CEF) Based Multi-layer Switching (MLS)

The leading-edge Catalyst switches, as listed in Table 9-1, use the CEF-based MLS forwarding model to download the control plane information such as the access lists to the data plane on the supervisor, port, or line card for hardware switching of packets. In the context of this chapter, the control plane represents the Layer 3 engine (route processor), and the data plane represents the hardware components such as ASICs used by the switch for hardware switching.

CEF is a topology-based forwarding model in which all routing information is pre-populated into a forwarding information base (FIB) and Layer 2 rewrite information is dynamically updated in an adjacency table. As a result of the pre-population of routing information, Catalyst switches can quickly look up routing information such as IP adjacencies and next-hop IP and MAC addresses.

The two main components of CEF are as follows

- Forwarding information base (FIB)—CEF uses a FIB to make IP destination prefix-based switching decisions. The FIB is conceptually similar to a routing table or information base. It maintains a mirror image of the forwarding information contained in the IP routing table. When routing or topology changes occur in the network, the IP routing table is updated, and those changes are reflected in the FIB. The FIB

maintains next-hop address information based on the information in the IP routing table. In the context of CEF-based MLS, both the Layer 3 engine and the hardware-switching components maintain a FIB.

- Adjacency tables—Network nodes in the network are said to be adjacent if they can reach each other with a single hop across a link layer. In addition to the FIB, CEF uses adjacency tables to store Layer 2 addressing information. The adjacency table maintains Layer 2 addresses for all FIB entries. As with the FIB, in the context of CEF-based MLS, both the Layer 3 engine and the hardware-switching components maintain an adjacency table.

CEF-based MLS separates the control plane hardware from the data plane hardware switching. Nevertheless, the control plane is responsible for building the FIB table and adjacency tables in software and then downloading this information to the data plane.

On the Catalyst 6500 family of switches, the control plane hardware is easily distinguishable from the data plane hardware, especially in the case of hybrid software. The Catalyst 6500 MSFC daughter card is responsible for the control plane operations, whereas the Supervisor and PFC module are responsible for the data plane operations. The Catalyst 3550, 3560, 3750, and 4500 families of switches do not have distinguishable control plane and data plane modules or daughter cards.

Catalyst switches do not support routing of all types of frames in hardware. For example, the following list details common frame types that are not supported by hardware switching:

- Packets with IP header options
- Packets sourced from or destined to tunnel interfaces
- Packets using Ethernet encapsulation types other than ARPA
- Packets that require fragmentation

Upcoming models of Catalyst switches may support these frame types in hardware. In addition, each Catalyst switch family has its own distinct list of frames not supported by hardware switching.

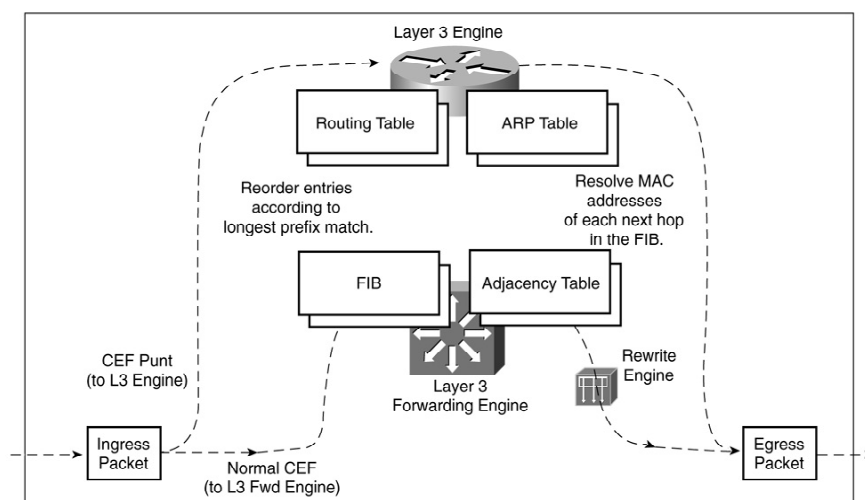


Fig 5.6: CEF BASED MULTI-LAYER SWITCHING

NetFlow switching has given way to a more efficient form of multilayer switching: Cisco Express Forwarding. Cisco developed CEF for its line of routers, offering high-performance packet forwarding through the use of dynamic lookup tables.

CEF also has been carried over to the Catalyst switching platforms. The following platforms all perform CEF in hardware:

- Catalyst 6500 Supervisor 720 (with an integrated MSFC3)
- Catalyst 6500 Supervisor 2/MSFC2 combination
- Catalyst 4500 Supervisor III, IV, and V
- Fixed-configuration switches, such as the Catalyst 3750, 3560, 3550, and 2950

CEF runs by default, taking advantage of the specialized hardware.

5.4 MPLS

Multiprotocol Label Switching (MPLS) is a protocol-agnostic routing technique designed to speed up and shape traffic flows across enterprise wide area and service provider networks.

MPLS allows most data packets to be forwarded at Layer 2 — the switching level — rather than having to be passed up to Layer 3 — the routing level. For this reason, it is often informally described as operating at Layer 2.5.

MPLS was created in the late 1990s as a more efficient alternative to traditional IP routing, which requires each router to independently determine a packet's next hop by inspecting the packet's destination IP address before consulting its own routing table. This process consumes time and hardware resources, potentially resulting in degraded performance for real-time applications such as voice and video.

In an MPLS network, the very first router to receive a packet determines the packet's entire route upfront, the identity of which is quickly conveyed to subsequent routers using a label in the packet header.

While router hardware has improved exponentially since MPLS was first developed — somewhat diminishing its significance as a more efficient traffic management technology— it remains important and popular due to its various other benefits, particularly security, flexibility and traffic engineering.

Components of MPLS

One of the defining features of MPLS is its use of labels — the L in MPLS. Sandwiched between Layers 2 and 3, a label is a four-byte — 32-bit — identifier that conveys the packet's predetermined forwarding path in an MPLS network. Labels can also contain information related to quality of service (QoS), indicating a packet's priority level.

MPLS labels consist of four parts:

- Label value: 20 bits
- Experimental: 3 bits
- Bottom of stack: 1 bit
- Time to live: 8 bits

The paths, which are called label-switched paths (LSPs), enable service providers to decide ahead of time the best way for certain types of traffic to flow within a private or public network.

How an MPLS network works

In an MPLS network, each packet gets labeled on entry into the service provider's network by the ingress router, also known as the label edge router (LER). This is also the router that decides the LSP the packet will take until it reaches its destination address.

All the subsequent label-switching routers (LSRs) perform packet forwarding based only on those MPLS labels — they never look as far as the IP header. Finally, the egress router removes the labels and forwards the original IP packet toward its final destination.

When an LSR receives a packet, it performs one or more of the following actions:

- Push: Adds a label. This is typically performed by the ingress router.
- Swap: Replaces a label. This is usually performed by LSRs between the ingress and egress routers.
- Pop: Removes a label. This is most often done by the egress router.

This diagram illustrates how a simple MPLS network works.

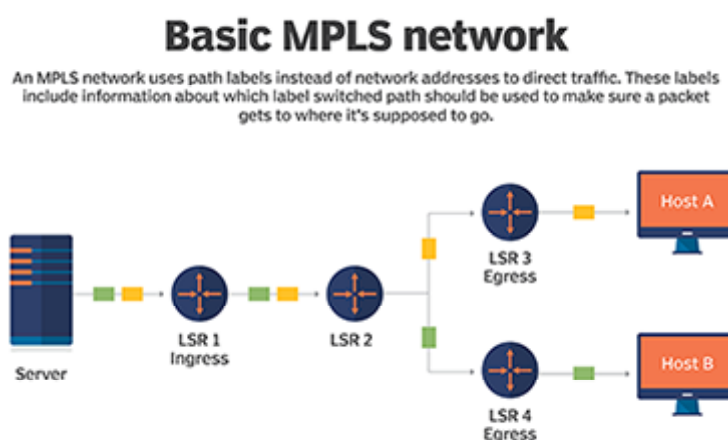


Fig 5.7 Basic MPLS Network

Advantages of MPLS

Service providers and enterprises can use MPLS to implement QoS by defining LSPs that can meet specific service-level agreements on traffic latency, jitter, packet loss and downtime. For example, a network might have three service levels that prioritize different types of traffic — e.g., one level for voice, one level for time-sensitive traffic and one level for best effort traffic.

5.5 Frame Mode MPLS Operation

In frame-mode MPLS, routers running MPLS exchange pure IP packets (penultimate hop popping) as well as labeled IP packets with one another in an MPLS domain. In an MPLS domain, label switching is done by parsing the frame header and then performing label imposition

(push), label disposition (pop), or label swapping depending on the LSR's location in the network. Data link layer connectivity in a frame-mode MPLS domain is established using serial HDLC/PPP, Ethernet, or ATM. ATM brings us to another aspect of Layer 2 connectivity where cells are used to transport IP packets. Note that although there might be ATM links in the MPLS domain, it is possible to run regular IP point-to-point links (routed PVCs). In such cases, it is still considered frame-mode MPLS and not cell-mode MPLS, although the Layer 2 protocol is ATM.

Frame-Mode MPLS Operation

Label allocation and distribution take place in frame-mode MPLS. The figure depicts two Edge LSRs, R1 and R4, connected via two LSRs, R2 and R3. After IGP convergence and LDP neighbor establishment, the LSRs assign a local label for 172.16.10.0/24 and propagate this label upstream. Therefore, the control and data structures, namely FIB, LFIB, and LIB, are populated with the appropriate values.

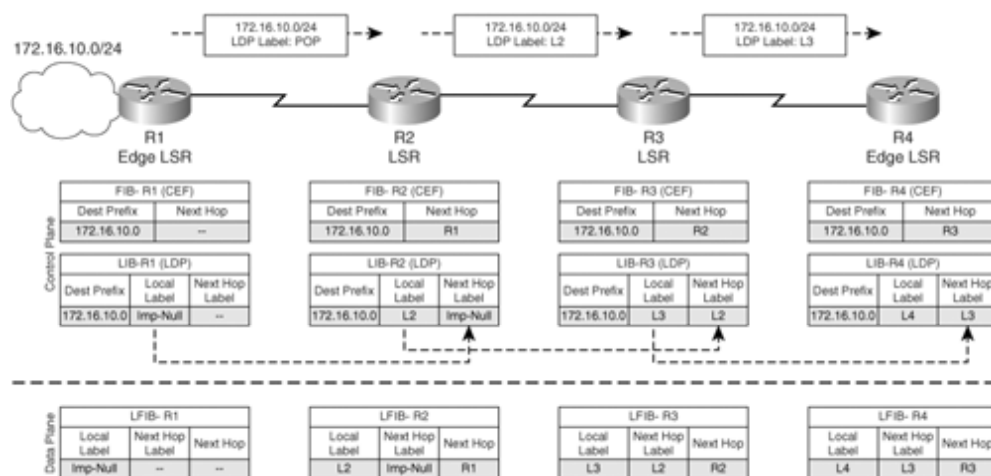


Fig 5.8 Frame-Mode MPLS Label Assignment and Distribution

Edge LSR R1 assigns an implicit-null local label and propagates the same upstream to LSR R2. LSRs R2 and R3 assign local labels L2 and L3, respectively, for destination network 172.16.10.0 and propagate them upstream. The label allocation can either be unsolicited downstream or downstream on demand label allocation; the only difference being that in downstream on demand label allocation, the upstream LSR requests a label for the destination network.

Forwarding a data packet destined for 172.16.10.0 via the MPLS domain is depicted, where the Edge LSR R4 imposes a label L3 (next-hop label as learned from downstream LSR) and forwards the labeled packet to the downstream LSR R3. R3 performs a label swap of ingress label L3 for egress label L2. On R2, the ingress label of L2 maps to an implicit-null label. Therefore, LSR R2 removes the top label (L2) and forwards the resultant IP packet to Edge LSR R1.

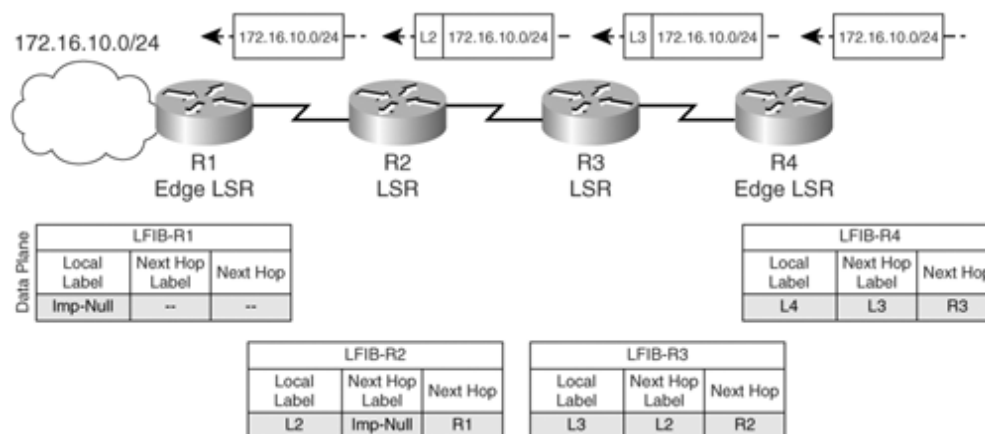


Fig 5.9 Frame-Mode MPLS Label Assignment and Distribution

Routers receiving a frame can identify the type of payload by the use of the protocol/type field in the frame header. For example, in the case of Ethernet, the 13th and 14th octets of an Ethernet or IEEE 802.3 packet (after the preamble) consist of the “Ethernet Type” or “IEEE 802.3 Length” field. A value of 0x0800 in these octets identifies an IP packet as the Layer 2 frame payload. A value of 0x8847 identifies an MPLS unicast payload in the Layer 2 frame. Thus, the router identifies the frame received on an interface as either containing an IP packet or a labeled IP packet.

5.6 MPLS VPN

An MPLS VPN is a virtual private network built on top of a service provider’s MPLS network to deliver connectivity between enterprise locations. Available in layer 2 or layer 3 options, the VPN leverages the multiprotocol and labeling capabilities of MPLS to deliver a flat, peer-to-peer network to link all of an organization’s remote sites into a common network. In most cases, MPLS VPN services are sold without encryption, typically relying on the fact that each customer is isolated from the others on his own private network. But for those customers that require it, encryption schemes such as IPsec can be added on top of the VPN configuration.

Summary

- A topology is a description of a layout or arrangement.
- The Bus topology within the WAN environment often covers small geographical areas i.e. within the same country.
- The Ring topology orientation has sites arranged in a ring. This is very similar to the Bus topology discussed earlier.
- With the Star topology, the sites are arranged in a star formation. There is a central hub and each site is connected directly to the hub.
- In the Mesh topology every device belonging to the network is connected to every other device in a mesh formation. This is quite different from the previous topologies where sites are connected to a maximum of two sites at a time.
- Forwarding information base (FIB): CEF uses aFIB to make IP destination prefix-based switching decisions. The FIB is conceptually similar to a routing table or information base.
- Multiprotocol Label Switching (MPLS) is a protocol-agnostic routing technique designed to speed up and shape traffic flows across enterprise wide area and service provider networks.
- An MPLS VPN is a virtual private network built on top of a service provider's MPLS network to deliver connectivity between enterprise locations.

Check your answers

- 1) What are the disadvantages of having a Bus Topology?
- 2) Write short notes on: Star and Mesh Topology.
- 3) Explain briefly the working MPLS
- 4) What are the components of MPLS?
- 5) What do you understand by MPLS VPN?

References

<https://www.lifewire.com/computer-network-topology-817884>

<https://www.networkworld.com/article/2297171/network-security-mpls-explained.html>

<https://www.nanog.org/meetings/nanog49/presentations/Sunday/mpls-nanog49.pdf>

<http://www.ciscopress.com/articles/article.asp?p=425816&seqNum=3>

Lesson - 6

Securing Wireless Networks

Learning Objectives

After reading this lesson you will be able to understanding the following:

- Overview of Wireless security
- Scanning and enumerating 802.11 Networks
- Attacking 802.11 Networks
- Attacking WPA Protected 802.11 Networks
- Bluetooth
- Bluetooth and Zigbee security
- Zigbee Attacks

Structure

- 6.1 Overview of Wireless Security**
- 6.2 Scanning and Ennumerating 802.11 Networks**
- 6.3 Attacking 802.11 Networks**
- 6.4 Attacking WPA Protected 802.11 Networks**
- 6.5 Bluetooth**
- 6.6 Bluetooth Eaves dropping**
- 6.7 Attacking and Exploiting**
- 6.8 ZIGBEE Attacks**

6.1 Overview of Wireless Security

Networks carry all sorts of confidential data, so security is a highly important part of any wireless network structure. Security ensures that the same level of data integrity and confidentiality as a wired network are maintained. Without properly implemented security measures, any wireless network adapter coming within range of another network adapter or access point can join the network. The amount of insecure wireless access points is alarming – a recent study showed how over 90% of Access Points have little or no security enabled.

6.2 Scanning and Enumerating 802.11 Networks

Choosing an Operating System

Various attack techniques rely upon the capabilities of the underlying hardware. This hardware depends on device drivers to communicate with the operating system, and device drivers are tied to a specific operating system. In addition, different wireless hacking applications only run on certain platforms. All combined, this dependency makes the selection of an operating system all that more important.

Windows

Windows probably has the advantage of already being installed on your laptop. The other advantage is that there is a very easy to install and use scanning tool called NetStumbler that runs on Windows. NetStumbler will be covered in detail in the tools portion of the chapter, but it is important to remember that NetStumbler is an *active* scanner.

The major downside to using Windows is the limited availability of passive scanners. A few exist, but these scanners are commercial products targeted at IT professionals. They are pricey and not really designed with war drivers (or even security professionals) in mind. Another real problem with using Windows is the lack of packet injection tools. There are a few applications that allow packet injection; however, no normal open-source tools exist that take advantage of it.

Linux

Linux is the obvious choice for wireless hacking. It has the most active set of driver developers, and most wireless tools are designed with Linux in mind. On Linux, drivers that support monitor mode are the norm, not the exception. Also, because the drivers are open source, it is easy to patch or modify them to perform more advanced attacks.

Of course, if you don't have much experience using Linux, configuring and installing custom kernel drivers and tools can be daunting. Fortunately, there are a variety of bootable CD distributions designed with security in mind, such as Knoppix-STD, Auditor, and PHLAK. Currently, Auditor seems to be the most actively maintained; this is probably the most important characteristic to have in a distribution that lives in a field that moves as quickly as wireless hacking.

OS X

OS X is a strange beast. While the core of the operating system is open, certain subsystems are not. OS X has a device driver subsystem that, while some people (myself included) consider very elegant, it isn't nearly as well-known as that of Linux or any BSD driver subsystem. This means there are not a lot of people out there hacking on device drivers for OS X. Furthermore, very few vendors supply any sort of OS X drivers at all, and if they do, they lack monitor mode and other useful features.

Fortunately for OS X users everywhere, there is one person, Michael (Mick) Rossberg, who is very talented and motivated when it comes to OS X drivers. Not only has he written a great passive scanner (Kismac) for OS X, he has also written the vast majority of device drivers required to get third-party wireless cards into monitor mode. Due in no small part to Mick's work, OS X has become a viable platform for wireless hacking.

Monitor mode is easy to come by for most popular chipsets, and packet injection is also available, though not as robust as it is on Linux. In short, OS X is just as capable as Linux when it comes to 802.11 scanning tools; however, Linux is still significantly ahead when it comes to penetration tools.

6.3 Attacking 802.11 Networks

Configuration Related Attacks

As their name implies, configuration related attacks stem from issues within the way the wireless network has been deployed. These types of vulnerabilities are normally easy to take advantage of and are often the result of an oversight, or ignorance on the behalf of those responsible for the network.

WPA/802.11i can be run in either home or enterprise mode. Home mode means that the AP and all the clients are using a pre-shared key (PSK). Enterprise mode means that the organization is using a RADIUS server for authentication. Despite the name, many businesses use PSK (home) mode because it's much easier to deploy. Figure 6.1 shows the authentication details when using a pre-shared key with WPA.

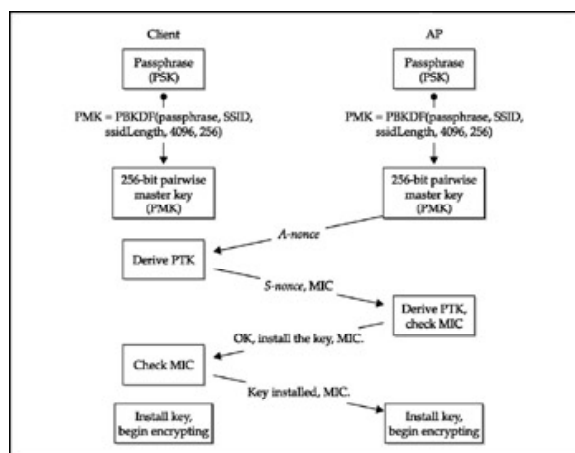


Fig 6.1: A successful four-way handshake, using a PMK derived from a passphrase

AP Impersonation

The AP impersonation attack was originally developed to trick unsuspecting clients to connect to an attacker controlled wireless network. This can be achieved by establishing an access point with the same SSID (Service Set Identifier) as the target networks.

For instance, if Acme Inc. has configured its wireless network with the SSID of “AcmeCorp”, wireless clients will probe (a process where the client blindly sends broadcast requests to identify if the wireless network it is configured for is nearby) for that SSID. If the “AcmeCorp” wireless network is nearby, then all “AcmeCorp” access points will send a probe response out to the client and, based on signal quality and strength, the client will associate to the access point within the wireless network which it feels will provide the best connection. An observant attacker can configure an access point to respond to “AcmeCorp” requests and, ultimately trick the client into connecting to its access point. The attacker can then monitor, control, or modify any of the traffic sent to and from the client. Another important note is that as long as the client’s wireless adapter is turned on, the client system will always probe to see if it’s in range of the wireless networks for which it’s configured. So, these attacks do not need to be launched near the same physical location of the corporate network in order to be successful.

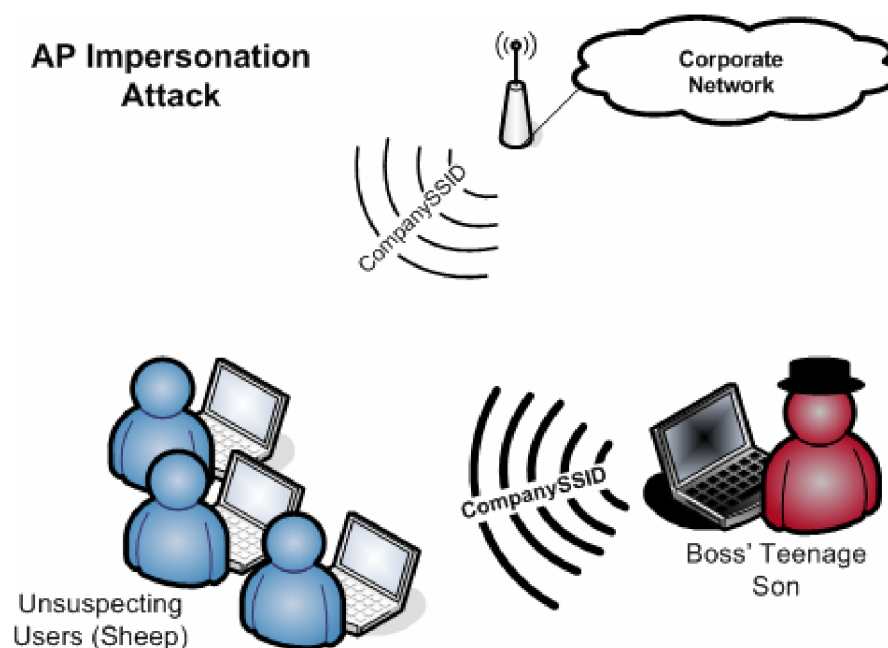


Fig 6.2: AP Impersonation Attack

The AP Impersonation attack has been recently revitalized with new attacks against WPA Enterprise. Joshua Wright and myself have come together to release a modified version of Free RADIUS (an open sourced RADIUS authentication server), named Free RADIUS-WPE. This RADIUS server, when used in conjunction with the AP Impersonation attack, can yield unauthorized access to not only the wireless network but possibly the Windows Domain. This attack targets EAP/TTLS and PEAP networks. Both EAP/TTLS and PEAP have the ability of establishing mutual authentication between the client and the authentication server prior to passing its inner authentication credentials (most often MSCHAPv2). It is common, however, that client systems are not properly configured to validate the authentication server's TLS certificate or the client supplicant puts the decision to decide whether or not to connect with a non-validated certificate. By impersonating the target wireless network, an attacker can trick the client into connecting to the malicious access point and ultimately obtain the client's inner authentication credentials. Depending on the inner authentication protocol used, these credentials can be passed in clear text, or may be subject to a brute force attack. Finally, because it is commonplace to use Windows Domain authentication credentials in EAP/TTLS and PEAP configurations, the attacker may also gain access to the corporate domain.

Implementation Attacks

Implementation attacks target systemic issues within the way IEEE 802.11 or its supporting technologies have been designed.

WEP Cracking

WEP is widely publicized as an insecure protocol; so much that in 2005, the FBI demonstrated defeating WEP in approximately three minutes. While the testing conditions were optimal, due to research by a group of cryptographic researchers at Darmstadt University in Germany, this feat can be accomplished with little effort in what was once considered subprime conditions. Named “aircrack-ptw”, this attack confirms WEP’s deficiencies by greatly reducing the time it takes to recover a key.

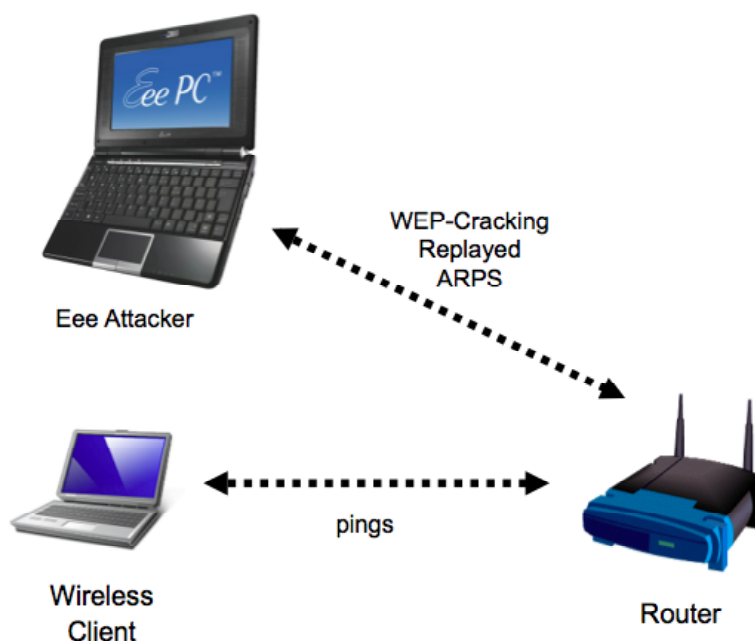


Fig 6.3: WEP Cracking Overview

Performing the Attack

Aircrack-ng: A variety of methods are available and very well documented for cracking WEP. Aircrack-ng.org’s tutorial section contains all of the step by step instructions anyone can possibly need for cracking WEP. Also, since aircrack-ng 0.9.0, the aircrack-ptw attack has been included.

Dynamic WEP

One of the first attempts in addressing the problems associated with WEP was something called Dynamic WEP. Dynamic WEP operates very similar to the way WPA Enterprise works by relying on IEEE 802.1x for authentication. The obvious difference between WPA Enterprise and Dynamic WEP is the use of WEP for data encryption. Dynamic WEP establishes two keys: a broadcast key and a session key. As its name implies, the broadcast key is a shared key which is used to encrypt broadcast traffic. The session key is unique to each individual user and is used to encrypt unicast traffic. Without possibly effecting users, the safest and lowest amount of time between key rotations is 5 minutes. This still doesn't add any additional level of protection as an attacker can break the key within the time it rotates. So now the attacker can inject and decrypt within the timeframe the key remains constant

Performing the Attack

To identify when the key is being rotated, take about 30 minutes and capture all the traffic you can. Filter on "eapol" within Wireshark to identify when the key has been rotated.

Café Latte Attack

Another WEP related attack is the "Café Latte Attack", discovered by two researchers at AirTight Networks. This attack demonstrated that an attacker can recover a WEP key without being in the same vicinity of the corporate wireless network by targeting isolated clients in public areas such as airports or coffee shops.

Performing the Attack

wep0ff: The wep0ff tool was written by Sergey Gordeychik, a Russian researcher from Positive Technologies (possibly renamed to Max Technologies) around the same time researchers from AirTight introduced the Café Latte Attack. It's unclear whether Sergey was first to develop the idea. However, AirTight does note in their presentation that wep0ff did exist, although it used a different and less effective method of performing their attack.

WPA-PSK Cracking

As described above, WPA Pre-Shared Key can be subject to a brute force attack if the 4-way handshake used in establishing the connection between the client and the access point is

observed and recorded. This can be forced by leveraging the de-authentication denial of service attack. An attacker can momentarily force the client to disconnect from the network, so that the attacker can capture the 4-way handshake when the client reconnects. As you review these attacks, keep an eye on the speed in which it takes to crack the key.

Hardware/Software Attacks

Vulnerabilities within client software, client drivers, access point operating systems, etc... can all be categorized as hardware/software attacks. These attacks stem from the lack of proper bounds checking and other issues most commonly found in applications. However, the impact is much greater as they can often result in remote compromise of the system/device or unauthorized access to the wireless network.

Wireless Client Adapters

In recent years, a number of vulnerabilities were identified in wireless adapter drivers which allowed remote compromise. David Maynor and Johnny Cache gave a controversial presentation at the BlackHat security conference which demonstrated a flaw within a wireless device driver that allowed remote compromise of an Apple Macbook. Another issue identified in Intel wireless device drivers also yielded the same results on Windows systems. These are all systemic issues due to poor input validation and application development and are traditionally the more common types of attacks seen at the high layers of the OSI model.

Fuzzing

Due to the closed source nature of Windows device drivers and wireless infrastructure devices, vulnerability discovery is often left up to the work of fuzzing. Fuzzing is the process of injecting random data into the areas of an application which accept input. This process can result in the application crashing, often indicating a lack of proper bounds checking. For instance, if the SSID field of a client probe request was fuzzed, and the access point crashed due to specific input, the attacker can deduce that there may be an issue in the access point's operating system code which may warrant further, more targeted, input testing. This process is usually performed in a testing environment, rather than used as an active attack.

Denial of Service Attacks

Denial of Service attacks result in a disruption of the connection between an authorized client and the access point. Generally speaking, 802.11 wireless networks are more susceptible

to these types of attacks because the standard heavily relies on the use of MAC addresses for identification.

De-authentication Attack

As mentioned previously, the IEEE 802.11 standard defines certain conditions where the client must obey an instruction originating from the access point to which it is associated. This Denial of Service attack takes advantage of this behaviour by forging 802.11 management frames in a way which tricks the client into thinking the access point wishes it to disconnect. Normal client behaviour will immediately attempt to reconnect the client to the access point. However, by flooding the client with de-authentication frames, an attacker can effectively force the client to constantly reconnect and disconnect.

6.4 Attacking WPA protected 802.11 Networks

There are a number of exploits available against Wi-Fi Protected Access (WPA). These include both data integrity/confidentiality attacks and Denial of Service (DOS) attacks. In the integrity/confidentiality realm a passive monitoring or dictionary attack on pre-shared keys is public knowledge as well as security issues around Rivest Cipher 4 (RC4), the underlying encryption protocol. On the DOS front, several attacks are available either by exploiting a specific feature of the protocol or by using the wireless standby of radio frequency jamming.

First the data integrity/confidentiality attacks are discussed, followed by the DOS attacks.

Data Integrity/Confidentiality Attacks

Of the types of attacks covered in this document, data integrity/confidentiality attacks potentially have the greatest risk and exposure in many environments since these attacks can go undetected and leave confidential data openly available to potentially hostile parties, including competitors. The attacks discussed here include a passive monitoring and a dictionary attack against the pre-shared key mode of WPA, as well as, attacks against the Rivest Cipher 4 (RC4) algorithm used for packet encryption.

Pre-Shared Key (PSK) Attacks

A pre-shared key (PSK) is a 256-bit number or a pass phrase 8 to 63 bytes long. Each Access Point (AP), when configured in PSK mode, has a single PSK which is used to generate session keys for each user connecting to the AP.

The PSK attacks are more relevant to home or small business users than large enterprises as larger organizations are more likely to set up RADIUS servers for authentication, rather than using PSK.

Pre-SharedKey (PSK) Monitoring Attack

The Pre-Shared Key (PSK) Monitoring attack is performed by the attacker, obtaining the basic information communicated between the client and Access Point (AP), and then generating the Pairwise Transient Key (PTK) for a session, using the already known PSK.

The attacker does this by passively listening as another client on the network connects to the Access Point (AP). All necessary information for generating the PTK is readily available: client and AP MAC addresses; 2 nonce from the 4-way handshake; and the selected cipher suite. Once the attacker has this set of information, he can generate the PTK which is a Keyed Hash Message Authentication Code (HMAC), using the PTK (already known by the attacker), two MAC addresses, and the two nonce from the first two packets of the 4-way handshake. At this point, an attacker can decrypt any packets another user of the network may send.

Pre-Shared Key (PSK) Dictionary Attack

If the attacker does not know the Pre-Shared Key (PSK), they may perform the Pre-Shared Key Dictionary attack to attempt to determine the key. For user selected pass phrases (PSK)s of less than 20 characters, this type of attack is expected to be successful.

Rivest Cipher 4 (RC4) Attack

Although no specific attacks on Rivest Cipher 4 (RC4) in Wi-Fi Protected Access (WPA) have been published, RC4 has several deficiencies in its security as a cipher which were discovered in its usage for the Wired Equivalent Privacy (WEP) protocol.

One attack identified by Fluhrer and McGrew can separate out the key stream from the cipher when provided a gigabyte of data. Although this is substantial network traffic, a passive listener, on a relatively idle wireless network, could collect this data over time, or could collect this data much more rapidly on an active network.

Another attack identified by Fluhrer, Mantin and Shamir found that the first few bytes of an output key stream have patterns which allow for the detection of information about the encryption key.

Denial of Service (DOS) Attacks

Denial of Service (DOS) attacks are a nuisance attack, leaving clients without wireless network coverage in a service area for a period of time. The DOS attacks discussed here include an attack that was inadvertently exposed as part of the security in the WPA protocol and a well-known attack that exists due to the underlying use of radio frequencies for wireless networks. Each is discussed in the following sections.

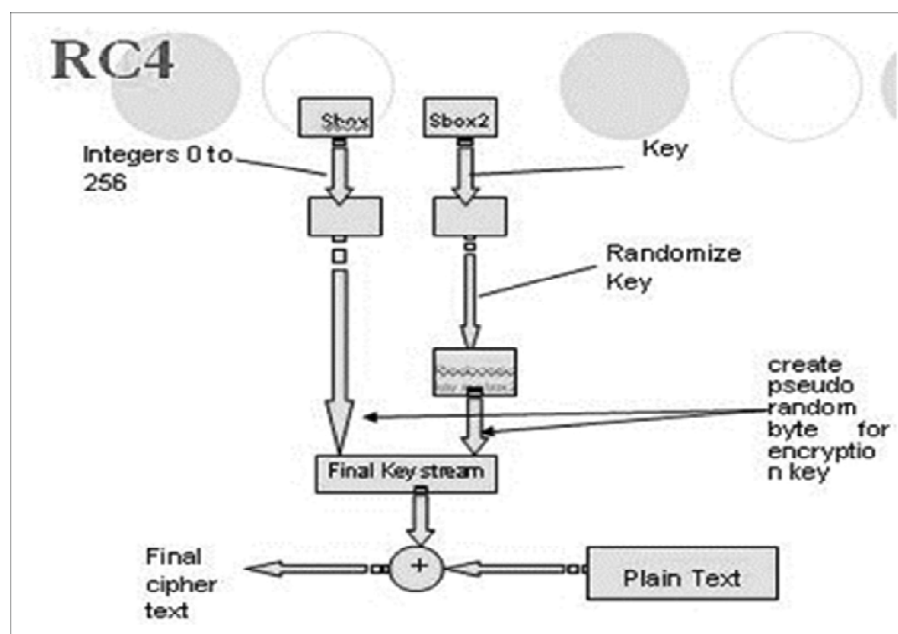


Fig 6.4: RC4 Attack

Wi-Fi Protected Access (WPA) Protocol Shutdown Attack

In Wi-Fi Protected Access (WPA)'s quest for improved security, it exposed itself to a Denial of Service (DOS) vulnerability within its protocol. This vulnerability occurs because WPA will shut down whenever it detects two attack packets (packet forgeries) from a client to an Access Point (AP) within a 1 second window. In this case, two packets with invalid Message Integrity Check (MIC)s. In the shutdown process, the AP will delete its keys and disconnect all clients, wait a minute and then reconnect with the clients. This allows for malicious clients to sit on the network, forging packets to the AP, shutting down service for users of the AP. With high frequencies of these forged packets, it can cause the AP to be nearly perpetually unavailable and thus unusable to clients.

The solution to this attack is to employ Access Control Lists (ACL)s for APs such that only valid clients can access the APs services.

Radio Frequency (RF) Jamming Attack

This Denial of Service (DOS) exploit is available in all wireless networking protocols. With this exploit a radio frequency jamming device can be used to disrupt client communications with Access Points (AP) in a service area.

The solution to this attack is to secure the perimeter of the service area, where possible. However, this is not always possible in open areas like coffee shops and university campuses.

6.5 Bluetooth

Bluetooth is wireless technology standard for exchanging data over short distances using short-wavelength UHF radio waves in the ISM band , industrial scientific and medical radio bands from 2.400 to 2.485 GHz from fixed and mobile devices, and building personal area networks (PANs). It was originally conceived as a wireless alternative to RS-232 data cables.

Bluetooth is managed by the Bluetooth Special Interest Group (SIG), which has more than 30,000 member companies in the areas of telecommunication, computing, networking, and consumer electronics. The IEEE standardized Bluetooth as IEEE 802.15.1, but no longer maintains the standard .The Bluetooth SIG oversees development of the specification, manages the qualification program, and protects the trademarks .A manufacturer must meet Bluetooth SIG standards to market it as a Bluetooth device. A network of patents apply to the technology, which are licensed to individual qualifying devices. Bluetooth is a standard wire-replacement communications protocol primarily designed for low power consumption, with a short range based on low-cost transceiver microchips in each device. Because the devices use a radio (broadcast) communications system, they do not have to be in visual line of sight of each other; however, a quasi-optical wireless path must be viable. Range is power-class-dependent, but effective ranges vary in practice. See the table “Ranges of Bluetooth devices by class”.

Bluetooth 1.0 and 1.0B

Versions 1.0 and 1.0B had many problems, and manufacturers had difficulty making their products interoperable. Versions 1.0 and 1.0B also included mandatory Bluetooth hardware device address (BD_ADDR) transmission in the Connecting process (rendering anonymity

impossible at the protocol level), which was a major setback for certain services planned for use in Bluetooth environments.

Bluetooth 1.1

- Ratified as IEEE Standard 802.15.1–2002
- Many errors found in the v1.0B specifications were fixed.
- Added possibility of non-encrypted channels.
- Received Signal Strength Indicator (RSSI).

Bluetooth 1.2

Major enhancements include:

- Faster Connection and Discovery
- Adaptive frequency-hopping spread spectrum (AFH), which improves resistance to radio frequency interference by avoiding the use of crowded frequencies in the hopping sequence.
- Higher transmission speeds in practice than in v1.1, up to 721 kbit/s.
- Extended Synchronous Connections (eSCO), which improve voice quality of audio links by allowing retransmissions of corrupted packets, and may optionally increase audio latency to provide better concurrent data transfer.
- Host Controller Interface (HCI) operation with three-wire UART.
- Ratified as IEEE Standard 802.15.1–2005
- Introduced Flow Control and Retransmission Modes for L2CAP.

Bluetooth 2.0 + EDR

This version of the Bluetooth Core Specification was released in 2004. The main difference is the introduction of an Enhanced Data Rate (EDR) for faster data transfer. The bit rate of EDR is 3 Mbit/s, although the maximum data transfer rate (allowing for inter-packet time and acknowledgements) is 2.1 Mbit/s. EDR uses a combination of GFSK and phase-shift keying modulation (PSK) with two variants, $\pi/4$ -DQPSK and 8-DPSK. EDR can provide a lower power consumption through a reduced duty cycle.

The specification is published as Bluetooth v2.0 + EDR, which implies that EDR is an optional feature. Aside from EDR, the v2.0 specification contains other minor improvements, and products may claim compliance to “Bluetooth v2.0” without supporting the higher data rate. At least one commercial device states “Bluetooth v2.0 without EDR” on its data sheet.

Bluetooth 2.1 + EDR

Bluetooth Core Specification Version 2.1 + EDR was adopted by the Bluetooth SIG on 26 July 2007. The headline feature of v2.1 is secure simple pairing (SSP): this improves the pairing experience for Bluetooth devices, while increasing the use and strength of security.

Version 2.1 allows various other improvements, including extended inquiry response (EIR), which provides more information during the inquiry procedure to allow better filtering of devices before connection; and sniff subrating which reduces the power consumption in low-power mode.

Bluetooth 3.0 + HS

Version 3.0 + HS of the Bluetooth Core Specification was adopted by the Bluetooth SIG on 21 April 2009. Bluetooth v3.0 + HS provides theoretical data transfer speeds of up to 24 Mbit/s, though not over the Bluetooth link itself.

6.6 Bluetooth Eavesdropping

The pairing process is a main contributor to security issues found in Bluetooth Attacks can be performed during different stages of the pairing process including before the pairing process has completed and after devices are paired. For example, attackers may be able to carry out Man-in-the-Middle attacks based on information they collected after pairing.

6.7 Attacking and Exploiting

A. MAC Spoofing Attack

The attack is performed before encryption is established and during the formation of the piconet when link keys are being generated. Devices are able to authenticate each other by generating link-keys. During the attack, attackers can imitate another user. They also have the ability to terminate connections or intercept/modify data with the use of special tools. The diagram below illustrates a MAC Spoofing attack.

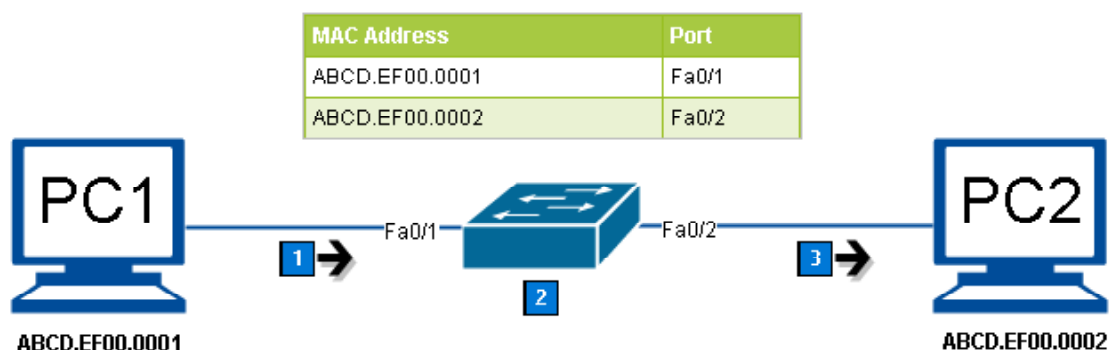


Fig 6.5: MAC Spoofing

B. PIN Cracking Attack

The attack occurs during the device pairing and authentication process. An attacker uses a frequency sniffer tool to collect the RAND and the BD_ADDR of the targeted device. A brute-force algorithm (E22 algorithm) is then used to test all possible permutations of the PIN with the data previously collected until the correct PIN is found.

C. Man-in-the-Middle Attack

Man-in-the-Middle (MITM) Attacks such as the one illustrated in Figure 6.6 below occur when devices are attempting to pair. During the attack, messages are relayed unknowingly between the devices. This enables authentication without the shared secret keys. In a successful attack, the user believes the pairing was successful; however, this is not the case, as the two devices are paired to the attacker.

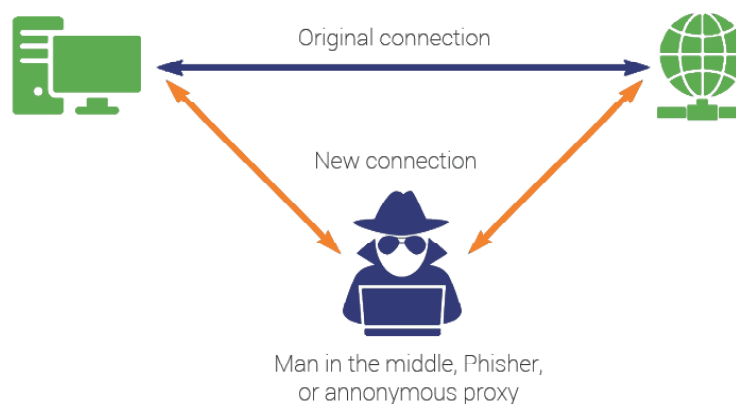


Fig 6.6: MITM Attack

D. Blue Jacking Attack

During a Blue Jacking attack, the attacker sends unsolicited messages to a device to trick the user into using an access code. This enables the adversary to access files on the targeted device. The devices involved in the attack and the exact source of the message received need to be within a specific range, 10 m, for the attack to be successful. This attack is commonly used in crowded areas (e.g., airports, shopping malls, and train stations). While it does not usually involve the alteration of data, it could make devices susceptible to other attacks.

E. Blue Snarfing Attack

The attack involves hacking into a mobile phone and stealing any of the data stored in the phone's memory, such as contacts, calendar entries, images, etc. During the attack, the attacker connects by exploiting the OBEX File Transfer Protocol, a file transfer program used in Bluetooth. This enables the attacker to pair with the user's device. Figure 6.7 below illustrates a Blue Snarfing attack.

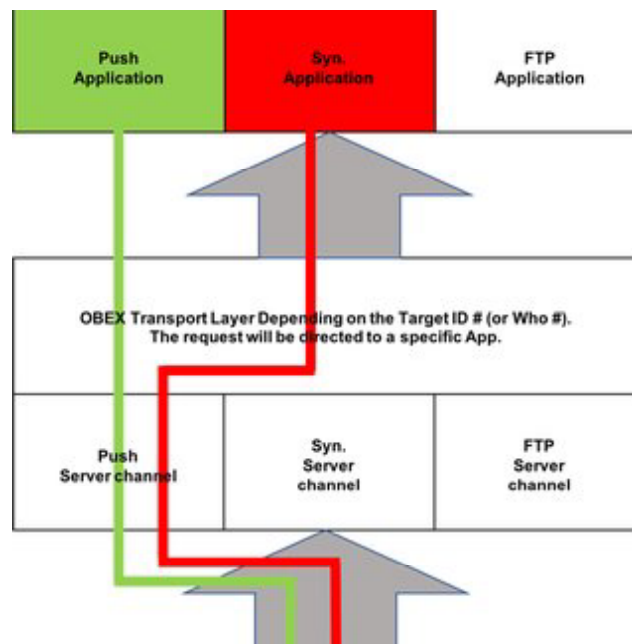


Fig 6.7: Bluesnarfing Attack

F. Blue-over Attack

Blue-over and its successor Blue-over II are auditing tools that are used to determine if a Bluetooth device is vulnerable, but they can also be used to initiate a BlueBugging attack.

G. Reflection/Relay Attack

The attack occurs when the adversary impersonates a device. The attacker is not looking for any undisclosed information during the attack. It simply authenticates the connection by reflecting/relaying device information.

6.8 ZIGBEE Attacks

Introduction

ZigBee is an open-source wireless technology used in low-powered embedded devices (radio systems) to facilitate efficient and effective machine-to-machine communication (typically 10-100 meters apart) while keeping the costs low. ZigBee is built on IEEE 802.15.4 standard and is supported by the ZigBee Alliance (a consortium of companies aiming to standardize the ZigBee Protocol).

Zigbee Architecture:

The ZigBee protocol stack consists of four layers – Physical layer, Medium access control (MAC) layer, Network layer (NWK) and Application layer (APL) – as shown in Figure 6.8 below. Each layer provides a set of services exposed to the upper layer via a service access point. The physical and MAC layers are governed by IEEE 802.15.4 standard and the network and application layers are governed by the ZigBee standard.

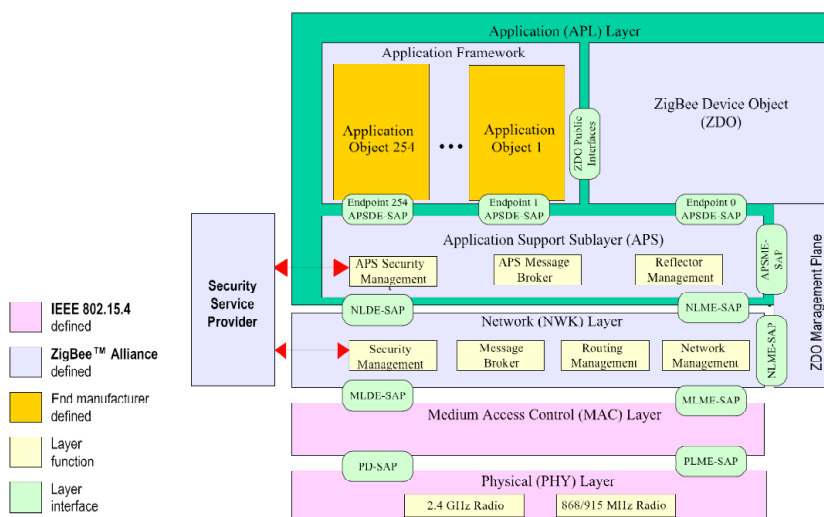


Fig 6.8: Zigbee Architecture

ZigBee is based on 802.15.4 protocol, but however, security is not very well implemented by the developers in ZigBee. This has attracted a lot of information security professional to look into the security capabilities of the 802.15.4 protocol and also the implementation of ZigBee radios in the IoT devices. The numerous attacks against ZigBee has been identified and can be classed under the following categories namely:

- **Sniffing**

Some ZigBee networks do not use proper encryption and attackers can take this advantage to sniff all the communications with the use of proper equipment. Sniffing attack in a ZigBee network generally refers to the process of collecting all the available information from a network, which is possible in a network which implements the standard generic security level protocols for communication. This can be prevented by implementing high security by preinstalling the network key on the ZigBee devices.

- **Replay attacks**

A replay attack is a kind of key-based attack where the attacker records approved traffic on a network and replay it at a later time to cause malicious effects. These attacks are straight forward in case of ZigBee's which do not implement a strong encryption or do not implement encryption for communication at all. Replay attack can be evaded with the use and implementation of freshness counter. With these counters implemented, every packet of data which gets transmitted is assigned a freshness number and the counter is thus incremented for every such packet of data, and these packets only get accepted only if their count is greater than that of the freshness counter's measuring their count. However proper conduct and usage of these counter might prove to be very gruelling for the administrator of the ZigBee network who monitors it as he/she has to manually do it.

- **Physical Attacks**

This type of attack is the most common and involves tampering with the devices in the ZigBee devices by locating it. In fact, hard coded encryption key which might be loaded into the RAM memory are often employed by many radios operating on the ZigBee network, once the device is powered. Now, as these devices in the network are distributed and flashed, the probability of replacing these keys are very less and having known these issues, the attackers can set up special serial interfaces in order to intercept the encryption key in the ZigBee device when the power rises from flash to RAM. There are various low-cost devices like Bus Pirate and

GoodFet which can be used for the above-mentioned exploit, thus proving the entire ZigBee network detrimental.

• **Denial-of-Service**

There are numerous methods other than the one mentioned above to disrupt the ZigBee network thereby rendering it unsafe. Signal jamming, reflexive jamming, maximization of frame counter are to name a few. Maximizing the frame counter is one of the most common examples of DOS in a ZigBee network, where the MIC is not verified and the frame counter is set to the maximum possible value, thus using the frame counter to ignore legitimate data packets. In this case, even if the contents of a packet transmitted are unintelligible and meaningless still the frame counter value will be accepted. Now the legitimate data packets received after the malicious packets with lower frame counter value will be ignored.

Summary

- Configuration related attacks stem from issues within the way the wireless network has been deployed. These types of vulnerabilities are normally easy to take advantage of and are often the result of an oversight, or ignorance on the behalf of those responsible for the network.
- The AP impersonation attack was originally developed to trick unsuspecting clients to connect to an attacker controlled wireless network.
- WEP is widely publicized as an insecure protocol; so much that in 2005, the FBI demonstrated defeating WEP in approximately three minutes.
- Aircrack-ng: A variety methods are available and very well documented for cracking WEP.
- Dynamic WEP operates very similar to the way WPA Enterprise works by relying on IEEE 802.1x for authentication.
- WPA Pre-Shared Key can be subject to a brute force attack if the 4-way handshake used in establishing the connection between the client and the access point is observed and recorded
- Fuzzing is the process of injecting random data into the areas of an application which accept input.

- During a Blue Jacking attack, the attacker sends unsolicited messages to a device to trick the user into using an access code. This enables the adversary to access files on the targeted device.
- The attack involves hacking into a mobile phone and stealing any of the data stored in the phone's memory, such as contacts, calendar entries, images, etc.
- ZigBee is an open-source wireless technology used in low-powered embedded devices (radio systems) to facilitate efficient and effective machine-to-machine communication (typically 10-100 meters apart) while keeping the costs low.

Check your Answers

- 1) What is AirCrack-ng used for?
- 2) Write short notes on: WPA protocol Shutdown Attack and RF Jamming attack
- 3) How is WEP cracking done?
- 4) Explain in brief Replay Attacks.
- 5) What are ZigBee Attacks?

References

- <https://www.google.com/amp/techgenix.com/overview-wireless-network-security/amp/>
- <https://en.m.wikipedia.org/wiki/Bluetooth>
- <https://securitycommunity.tcs.com/infosecsoapbox/articles/2017/11/03/different-attacks-and-counter-measures-against-zigbee-networks>

Lesson – 7

AD-HOC Network Security

Learning Objectives

After reading this lesson you will be able to understanding the following:

- Security in Ad-hoc Wireless Networks
- Network Security Requirements
- Issues and challenges in Security Provisioning
- Network Security Attacks
- Key Management in Ad-hoc Wireless Networks
- Secure Routing in Ad-hoc Wireless Networks

Structure

- 7.1 Security in Wireless Ad-hoc Networks**
- 7.2 Issues and Challenges in Security Provisioning**
- 7.3 Network Security Attacks**
- 7.4 Key Management in Ad-hoc Wireless Network**
- 7.5 Securing Routing in Ad-hoc Wireless Network**

7.1 Security in Wireless Ad-hoc Networks

Security is an important thing for all kinds of networks including the Wireless Ad Hoc Networks. It is obviously to see that the security issues for Wireless Ad Hoc Networks are difficult than the ones for fixed networks. This is due to system constraints in mobile devices as well as frequent topology changes in the Wireless networks. The system constraints include low-power, small memory and bandwidth, and low battery power. Everybody knows that the core requirement for military applications dealing with trust and security! That is to say, security is the most important issue for ad hoc networks, especially for those security sensitive applications. The main Ad-hoc Networks applications of MANET are in military and emergency, all these applications are security-sensitive. There are several factors of security that we should consider. In this process maintain and develop of all military information secured in wireless ad-hoc networks.

Availability

First, Availability ensures the survivability of network services despite denial of service attacks. This security criterion is challenged mainly during the denial-of-service attacks, in which all the nodes in the network can be the attack target and thus some selfish nodes make some of the network services unavailable area.

Confidentiality

Confidentiality ensures that certain information is never disclosed to unauthorized entities. In other words, in order to maintain the confidentiality of some confidential information, we need to keep them secret from all entities that do not have the privilege to access them.

Integrity

Integrity guarantees that a message being transferred is never corrupted. A message can be removed, replayed or revised by an adversary with malicious goal, which is regarded as malicious altering; on the contrary, if the message is lost or its content is changed due to some benign failures, which may be transmission errors in communication or hardware errors such as hard disk failure, then it is categorized as accidental altering.

Authentication

Authentication enables a node to ensure the identity of the peer node. If there is not such an authentication mechanism, the adversary could impersonate a benign node and thus get access to confidential resources, or even propagate some fake messages to disturb the normal network operations.

Non-repudiation

Non-repudiation ensures that the sender and the receiver of a message cannot disavow that they have ever sent or received such a message. This is useful especially when we need to discriminate if a node with some abnormal behaviour is compromised or not: if a node recognizes that the message it has received is erroneous, it can then use the incorrect message as an evidence to notify other nodes that the node sending out the improper message should have been compromised.

Authenticity

Authenticity is essentially assurance that participants in communication are genuine and not impersonators. It is necessary for the communication participants to prove their identities as what they have claimed using some techniques so as to ensure the authenticity. If there is not such an authentication mechanism, the adversary could impersonate a benign node and thus get access to confidential resources, or even propagate some fake messages to disturb the normal network operations.

Anonymity

Anonymity means that all the information that can be used to identify the owner or the current user of the node should default be kept private and not be distributed by the node itself or the system software. This criterion is closely related to privacy preserving, in which we should try to protect the privacy of the nodes from arbitrary disclosure to any other entities.

Ordering

Out-of-order updates can also affect the correctness of the routing protocols. These messages may not reflect the true state of the network and may propagate false information. Ad hoc routing protocols have sequence numbers that are unique within the routing domain to keep updates in order.

Timeliness

Routing updates need to be delivered in a timely fashion. Update messages that arrive late may not reflect the true state of the links or routers on the network. They can cause incorrect forwarding or even propagate false information and weaken the credibility of the update information. If a node that relays information between two large connected components is advertised as “down” by malicious neighbors, large parts of the network become unreachable. Most adhoc routing protocols have timestamps and timeout mechanisms to guarantee the freshness of the routes they provide.

7.2 Issues and Challenges in Security Provisioning

Designing a fool proof security protocol for ad hoc wireless is a very challenging task. This is mainly because of certain unique characteristics of ad hoc wireless networks, namely, shared broadcast radio channel, insecure operating environment, lack of central authority, lack

of association among nodes, limited availability of resources, and physical vulnerability. A detailed discussion on how each of the above-mentioned characteristics causes difficulty in providing security in ad hoc wireless networks is given below.

- **Shared Broadcast Radio Channel:** Unlike in wired networks where a separate dedicated transmission line can be provided between a pair of end users, the radio channel used for communication in ad hoc wireless networks is broadcast in nature and is shared by all nodes in the network. Data transmitted by a node is received by all nodes within its direct transmission range. So a malicious node could easily obtain data being transmitted in the network. This problem can be minimized to a certain extent by using directional antennas.

- **Insecure Operational Environment:** The operating environments where ad hoc wireless networks are used may not always be secure. One important application of such networks is in battlefields. In such applications, nodes may move in and out of hostile and insecure enemy territory, where they would be highly vulnerable to security attacks.

- **Lack of Central Authority:** In wired networks and infrastructure-based wireless networks, it would be possible to monitor the traffic on the network through certain important central points (such as routers, base stations, and access points) and implement security mechanisms at such points. Since ad hoc wireless networks do not have any such central points, these mechanisms cannot be applied in ad hoc wireless networks.

- **Lack of Association:** Since these networks are dynamic in nature, a node can join or leave the network at any point of the time. If no proper authentication mechanism is used for associating nodes with a network, an intruder would be able to join into the network quite easily and carry out his/her attacks.

- **Limited Resource Availability:** Resources such as bandwidth, battery power, and computational power (to a certain extent) are scarce in ad hoc wireless networks. Hence, it is difficult to implement complex cryptography-based security mechanisms in such networks.

- **Physical Vulnerability:** Nodes in these networks are usually compact and hand-held in nature. They could get damaged easily and are also vulnerable to theft.

7.3 Network Security Attacks

Like all kinds of networks, passive attack and active attack are two kinds of attacks which can be launched against ad hoc networks. The passive attacks only intercept the message

transmitted in the network without disturbing the transmission. By doing this, the attacker will be able to analyze the valuable information like network topology to perform further attacks. For example, by eavesdropping and subsequent analyses, the attacker may notice that some particular node is used much more than the others, which means it might be the 'heart' of this network. If this node is brought down, the whole network will be out of action as well. Then the attacker can deploy some special attacks to achieve this goal. Unfortunately, this kind of attack in wireless network is impossible to detect due to the nature of wireless network that its medium is air which is widely open to every user within the domain.

The active attacks are carried out by malicious nodes which aim to disrupt transmission among other nodes or selfish nodes which may just want to save their own battery. There are mainly three ways to perform such an attack.

Attacks using modification

Below we briefly talk about several modification attacks against Adhoc On - Demand Distance Vector Routing (AODV) and Dynamic Source Routing (DSR).

(1) Redirection by Modified Route Sequence Numbers:

Protocols such as AODV assign some value to routes to the specific destination to decide the priority. A route with a higher value is preferred. The node may change traffic through itself by advertising a route to a node with a greater value.

(2) Redirection with Modified Hop Counts:

Without other metrics, AODV uses the hop count field to determine a shortest path. Malicious nodes can reset the hop count field of the RREQ to zero so that increases the chance that they are included on a newly created route. Similarly, malicious nodes may be not included in the created routes if they set the hop count field of the Route Request (RREQ) to infinity.

(3) Denial-of-service with Modified Source Routes:

DSR uses source routes stating routes in data packets. These routes lack integrity checks. So, denial-of-service attack can be launched by altering the source routes in packet headers so that the packet can't be delivered to the destination.

Attacks using Fabrication

When a node mis-represent the identity in the network such as by altering MAC or IP address in outgoing packets, spoofing can occur. It can modify the routing of some nodes then lead to loops in the network which will increase the power consumption greatly.

Attacks using Impersonation

These attacks generate false routing messages which can be difficult to distinguish from invalid constructs.

(1) Falsifying Route Errors in AODV and DSR:

In ADOV and DSR, if the destination node or an intermediate node along the active path moves, the node upstream of the link break broadcasts a route error message to all active upstream neighbors. This message causes the corresponding route to be invalid. A denial-of-service attack can be achieved by sending route error messages indicating a broken link on the route, then prevent the source from communicating with destination.

(2) Route Cache Poisoning in DSR:

A node overhearing may add the routing information contained in the packet's header to its own route cache. An attacker can exploit this method of learning modify route caches by transmitting packets containing invalid routes in their headers.

7.4 Key Management in Ad-Hoc Wireless Networks

The security in networking is in many cases dependent on proper key management. Key management consists of various services, of which each is vital for the security of the networking systems. The services must provide solutions to be able to answer the following questions:

Trust model: it must be determined how much different elements in the network can trust each other. The environment and area of application of the network greatly affects the required trust model. Consequently, the trust relationships between network elements affects the way the key management system is constructed in network.

Cryptosystems: available for the key management: in some cases, only public- or symmetric key mechanisms can be applied, while in other contexts Elliptic Curve Cryptosystems (ECC) are available. While public-key cryptography offers more convenience (e.g. by well-

known digital signature schemes), public-key cryptosystems are significantly slower than their secret-key counterparts when similar level of security is needed. On the contrary, secret-key systems offer less functionality and suffer more from problems in e.g. key distribution. ECC cryptosystems are a newer field of cryptography in terms of implementations, but they are already in use widely, for instance in smart card systems

Key creation: it must be determined which parties are allowed to generate keys to themselves or other parties and what kind of keys.

Key storage: in ad-hoc networks there may not be a centralized storage for keys. Neither there may be replicated storage available for fault tolerance. In ad-hoc networks any network element may have to store its own key and possibly keys of other elements as well. Moreover, in some proposals such as in [19], shared secrets are applied to distribute the parts of keys to several nodes. In such systems the compromising of a single node does not yet compromise the secret keys.

Key distribution: the key management service must ensure that the generated keys are securely distributed to their owners. Any key that must be kept secret has distributed so that confidentiality, authenticity and integrity are not violated. For instance, whenever symmetric keys are applied, both or all of the parties involved must receive the key securely. In public-key cryptography the key distribution mechanism must guarantee that private keys are delivered only to authorized parties. The distribution of public keys need not preserve confidentiality, but the integrity and authenticity of the keys must still be ensured.

7.5 Secure Routing in Ad- Hoc Wireless Networks

Unlike the traditional wired Internet, where dedicated routers controlled by the Internet service providers (ISPs) exist, in ad hoc wireless networks, nodes act both as regular terminals (source or destination) and also as routers for other nodes. In the absence of dedicated routers, providing security becomes a challenging task in these networks. Various other factors which make the task of ensuring secure communication in ad hoc wireless networks difficult include the mobility of nodes, a promiscuous mode of operation, limited processing power, and limited availability of resources such as battery power, bandwidth, and memory. In the following sections, we show how some of the well-known traditional routing protocols for ad hoc networks fail to provide security. Some of the mechanisms proposed for secure routing are also discussed.

Requirements of a Secure Routing Protocol for Ad Hoc Wireless Networks

The fundamental requisites of a secure routing protocol for ad hoc wireless networks are listed as follows:

- **Detection of malicious nodes:** A secure routing protocol should be able to detect the presence of malicious nodes in the network and should avoid the participation of such nodes in the routing process. Even if such malicious nodes participate in the route discovery process, the routing protocol should choose paths that do not include such nodes.
- **Guarantee of correct route discovery:** If a route between the source and the destination nodes exists, the routing protocol should be able to find the route, and should also ensure the correctness of the selected route.
- **Confidentiality of network topology:** As explained in Section 9.10.1, an information disclosure attack may lead to the discovery of the network topology by the malicious nodes. Once the network topology is known, the attacker may try to study the traffic pattern in the network. If some of the nodes are found to be more active compared to others, the attacker may try to mount (e.g., DoS) attacks on such bottleneck nodes. This may ultimately affect the on-going routing process. Hence, the confidentiality of the network topology is an important requirement to be met by the secure routing protocols.
- **Stability against attacks:** The routing protocol must be self-stable in the sense that it must be able to revert to its normal operating state within a finite amount of time after a passive or an active attack. The routing protocol should take care that these attacks do not permanently disrupt the routing process. The protocol must also ensure Byzantine robustness, that is, the protocol should work properly even if some of the nodes, which were earlier participating in the routing process, turn out to become malicious at a later point of time or are intentionally damaged.

Summary

- Availability ensures the survivability of network services despite denial of service attacks.
- Confidentiality ensures that certain information is never disclosed to unauthorized entities.

- Integrity guarantees that a message being transferred is never corrupted.
- Authentication enables a node to ensure the identity of the peer node.
- Non-repudiation ensures that the sender and the receiver of a message cannot disavow that they have ever sent or received such a message.
- Authenticity is essentially assurance that participants in communication are genuine and not impersonators.
- Anonymity means that all the information that can be used to identify the owner or the current user of the node should default be kept private and not be distributed by the node itself or the system software.
- Out-of-order updates can also affect the correctness of the routing protocols.
- Protocols such as AODV assign some value to routes to the specific destination to decide the priority.
- Key management consists of various services, of which each is vital for the security of the networking systems.

Check your Answers

- 1) Write Short Notes on: IAAA
- 2) What do you understand by Non-repudiation? Explain with an example.
- 3) What are the various challenges faced while designing a secure protocol for ad - hoc wireless networks?
- 4) How are keys managed in ad – hoc wireless networks?
- 5) Why is secure routing protocol required for Ad Hoc Wireless Networks?

References

- Cryptography and Network Security : Principles and Practice (6th Edition) by William Stallings, Pearson Education Inc.
- <https://blog.systoolsgroup.com/ad-hoc-mode-wireless-network/>
- <https://www.lifewire.com/what-is-an-ad-hoc-wireless-network-2377409>
- <https://www.dummies.com/computers/computer-networking/wireless/how-to-set-up-a-wireless-ad-hoc-network/>

Lesson – 8

RFID SECURITY

Learning Objectives

After reading this lesson you will be able to understanding the following:

- Introduction to RFID
- RFID Security and Privacy
- RFID Chips – Technics and Protocols
- RFID anti-counterfeiting
- Man-in-the-middle attacks on RFID systems
- Digital Signature
- Transponder
- Combining Physics and Cryptography to Enhance Privacy in RFID Systems
- Scalability Issues in Large–Scale Applications

Structure

- 8.1 Introduction to RFID**
- 8.2 Security and Privacy**
- 8.3 RFID Chips - Techniques and Protocols**
- 8.4 RFID Anti-counterfeiting**
- 8.5 Man-in-Middle Attacks on RFID system**
- 8.6 Digital Signature**
- 8.7 Transponder**
- 8.8 Combining Physics and Cryptography to Enhance Security and Privacy in RFID System**
- 8.9 Scalability issues in Large Scale Applications**

8.1 Introduction

Radio Frequency Identification (RFID) technology is a non-contact, automatic identification technology that uses radio signals to identify, track, sort and detect a variety of objects including people, vehicles, goods and assets without the need for direct contact (as found in magnetic stripe technology) or line of sight contact (as found in bar code technology). RFID technology can track the movements of objects through a network of radio-enabled scanning devices over a distance of several metres. A device called an RFID tag (or simply a tag) is a key component of the technology.

An RFID tag usually has at least two components:

1. an integrated circuit for modulating and demodulating radio signals and performing other functions
2. an antenna for receiving and transmitting the signal. An RFID tag can perform a limited amount of processing and has small amount of storage. RFID tags are sometimes considered to be enhanced “electronic barcodes”

How does RFID Work?

Systems that make use of RFID technology are typically composed of three key elements:

1. An RFID tag, or transponder, that carries object-identifying data.
2. An RFID tag reader, or transceiver, that reads and writes tag data.
3. A back-end database, that stores records associated with tag contents.

Each tag contains a unique identity code. An RFID reader emits a low-level radio frequency magnetic field that energises the tag. The tag responds to the reader’s query and announces its presence via radio waves, transmitting its unique identification data. This data is decoded by the reader and passed to the local application system via middleware. The middleware acts as an interface between the reader and the RFID application system. The system will then search and match the identity code with the information stored in the host database or backend system. In this way, accessibility or authorisation for further processing can be granted or refused, depending on results received by the reader and processed by the database.

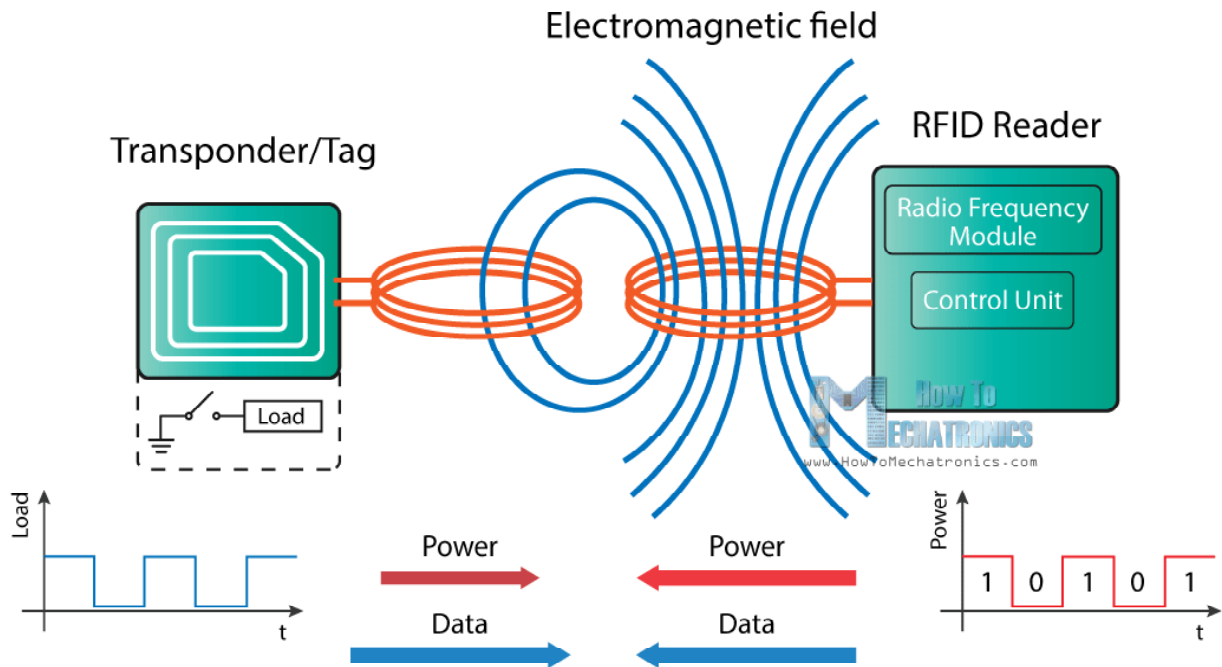


Fig 8.1 Overview of RFID

8.2 Security and Privacy

With the adoption of RFID technology, a variety of security and privacy risks need to be addressed by both organisations and individuals:

TAG DATA

RFID tags are considered “dumb” devices, in that they can only listen and respond, no matter who sends the request signal. This brings up risks of unauthorised access and modification of tag data. In other words, unprotected tags may be vulnerable to eavesdropping, traffic analysis, spoofing or denial of service attacks.



Fig 8.2: Different types of tags

The different types of attacks:

Eavesdropping (or Skimming)

Radio signals transmitted from the tag, and the reader, can be detected several metres away by other radio receivers. It is possible therefore for an unauthorised user to gain access to the data contained in RFID tags if legitimate transmissions are not properly protected. Any person who has their own RFID reader may interrogate tags lacking adequate access controls, and eavesdrop on tag contents.

Traffic Analysis

Even if tag data is protected, it is possible to use traffic analysis tools to track predictable tag responses over time. Correlating and analyzing the data could build a picture of movement, social interactions and financial transactions. Abuse of the traffic analysis would have a direct impact on privacy.

Spoofing

Based on the data collected from eavesdropping or traffic analysis, it is possible to perform tag spoofing. For instance, a software package known as “RFDump”, that runs on a notebook computer or personal digital assistant, allows a user to perform reading or writing tasks on most standard smart tags if they are not properly protected. The software permits intruders to overwrite existing RFID tag data with spoof data. By spoofing valid tags, the intruder could fool an RFID system, and change the identity of tags to gain an unauthorised or undetected advantage. One example is trying to save money by buying expensive goods that have had their RFID price tags spoofed to display cheaper prices.

By combining the two capabilities of eavesdropping and spoofing, a replay attack is possible where an attacker can “query a tag, receive the information it sends, and retransmit this information at a later time”.

Denial of Service Attack

The problems surrounding security and trust are greatly increased when large volumes of internal RFID data are shared among business partners. A denial of service attack on RFID infrastructure could happen if a large batch of tags has been corrupted. For example, an attacker can use the “kill” command, implemented in RFID tags, to make the tags permanently inoperative if they gain password access to the tags. In addition, an attacker could use an illegal high power radio frequency (RF) transmitter in an attempt to jam frequencies used by the RFID system, bringing the whole system to a halt.

Personal Privacy

As RFID is increasingly being used in the retailing and manufacturing sectors, the widespread item-level RFID tagging of products such as clothing and electronics raises public concerns regarding personal privacy. People are concerned about how their data is being used, whether they are subject to more direct marketing, or whether they can be physically tracked by

RFID chips. If personal identities can be linked to a unique RFID tag, individuals could be profiled and tracked without their knowledge or consent.

For instance, washing clothes tagged with RFID does not remove the chips, since they are specially designed to withstand years of wear and tear. It is possible that everything an individual, buys and owns is identified, numbered and tracked, even when the individual leaves the store, as far as products are embedded with RFID tags. RFID readers can detect the presence of these RFID tags wherever they are close enough to receive a signal.

8.3 RFID Chips – Techniques and Protocols

- Chip-less RFID Tags
- RFID Antenna Design
- Printed Electronic RFID Tags
- RFID Grids
- Advances in RFID Reader Design
- RFID Encoding Techniques
- UWB RFID Systems
- Energy Harvesting Techniques for RFIDs
- RFID Collision Avoidance Techniques
- Backscatter Communications
- RF Fingerprinting
- RF-DNA
- Physically Unclonable Functions (PUFs)
- Nanostructured PUFs
- Hardware Intrinsic Security
- RF Embedded Chip Security
- Secure Near-Field Communications
- Applied Cryptographic Algorithms
- Securing M2M Communications
- Securing IoTs

RFID CHIPS

RFID chips are quite similar to bar code labels in that they typically work with a corresponding scanner or reader. However, RFID chips have significant advantages. Because a RFID chip communicates with a reader through radio waves (not infrared, which is being used by bar code technology), the chip doesn't have to be positioned right in front of the reader. That is, line-of-sight is not needed.

Also, unlike a bar code reader/label pair, which have to be really close (about a few centimeters), some RFID reader/chip pairs can function even if they are a few meters apart. Furthermore, while a bar code label can only be read by a single reader at a time, a RFID chip can transmit data to multiple readers simultaneously.

There are different kinds of RFID chips. Some require batteries, known as active chips, while others don't (passive). Others are designed for indoor use or built for rugged, outdoor applications. The most common applications include object tracking and identification.

Chips can also differ in the kind of radio frequencies they operate on. Some communicate via Ultra High Frequency (UHF), High Frequency (HF) or Low Frequency (LF).

RFID chips can be attached just about anywhere: clothes, shoes, vehicles, containers and even plants, animals and human beings (as implants). Miniaturized chips have even been attached to insects.

RFID Protocols

A communications protocol is a way of organizing the conversation between devices — in the case of RFID, between tags and a reader — to ensure that information actually gets transferred. A protocol defines:

An Air Interface: what sort of modulation of the reader signal is used to define a binary one? what's a zero? what kind of signal does the tag send? how fast does everything go? is information sent in discrete packets, and if so how are they formed?

Medium Access Control: who gets to talk when? how are collisions between contending users (tags in this context) resolved?

Data Definitions: what sort of data is associated with a tag? what does it mean?

Passive RFID tags face some special problems not encountered in most other digital radio systems. Tags are cheap and dumb, so only changes in amplitude of the reader signal can be used; advanced modulations like phase-shift keying or quadrature-amplitude-modulation (QAM) are not available. Further, turning off the power from the reader reduces the power available to the tag, so the modulations of choice for the reader are those in which power is on most of the time; such modulations are wasteful users of spectrum, leading to relatively wide channels or low data rates. The tag reflection can be modulated in phase or amplitude, but the small tag reflection is combined with large reflections from the antenna and ambient, so that the resulting signal at the reader may change amplitude when the tag reflection changes phase, and so on. One can only hope to detect changes in state of the tag antenna, but not the type of change. The reader can count edges from the tag but not the absolute or differential phase or amplitude. Tag and reader symbols must be chosen with these constraints in mind.

There are numerous protocols using different approaches to each of these issues, and all of them work — but the reader and tag need to use the same one! In this discussion we'll briefly examine the UHF tag protocol that has been promulgated by EPCglobal for supply-chain tracking using passive RFID tags. The EPCglobal protocols assume the tag carries a unique identifier, the electronic product code (EPC). EPC's can be either 64 or 96 bits long (longer ID's are available for future use), and are partitioned into a header describing the EPC structure, some information about the 'manager' (typically a company owning some ID space), and other information about the type of object marked and the serial number.

8.4 RFID Anti-counterfeiting

RFID computing system is a technology whose use has become more and more diverse and has become pervasively applied in many environments. Initially the use of RFID systems was limited to low-impact applications like inventory and antitheft in the retail area. However, today RFID computing systems have been applied in sophisticated areas, such as in IDs and passports and pharmaceutical pedigrees, where their impact is critical to the success. There are multiple proposals of the use of RFID in future complex systems that will greatly impact the efficiency of these systems. In many cases, RFID has been implemented in a "behind-the-scene" scenario such as in a distribution center. In some other cases, RFID has been used in a merchant "antitheft" application while these tags are used in a manner that is directly interacting with consumers, these tags are removed once a purchase is completed. Such applications of RFID do not impact privacy. However, as RFID is applied in more sensitive applications, the

RFID computing system will become more pervasive, in terms of consumer effect, and so privacy and privacy-related issues will become more and more important. In order to successfully apply RFID to sensitive applications within the consumer mainstream, privacy preserving protocols need to be developed. The RFID system should reveal information only to those authorized and unauthorized parties should not be able to extract side information from the RF communications. Along with the identification function of RFID tags, anti-counterfeiting is one of the functions that tags will be able to provide. Examples of its use in an anti-counterfeiting system include embedding RFID tags in Euro banknotes, pharmaceutical products, or passports. Anti-counterfeiting is usually implemented by authenticating an item remotely or semi remotely. The party who authenticates the item is able to obtain its tag information as well. However, many RFID systems will operate in complex environments, so adversaries may tamper the tag information in many ways to fool the legitimate users of the wrong item. Preserve in integrity of tag data is key to trusting an RFID authentication system. Thus any protocol should consider integrity. Much of the past work on integrity mainly focused on the trust of operations. Due to the complexity of transactions and the number of custodians of a tag during its lifetime, an important focus should be on how to date the trust of tag information that has been obtained and modified by many parties. For example, we constructed a model, which we call perfect integrity of tag information. This model can be used to evaluate protocols that provide integrity of information and/or anti-counterfeiting protocols. In an integrity (anti-counterfeiting) application, passive RFID tags could possibly be embedded into product to reduce the cost. The chip may only be capable of preliminary computing like exclusive-or and does not have a lot of memory space, perhaps about 1 Kbits. Although the tag may have memory access control through a key, it should not be relied on, since the key is usually transmitted clear in air, which will be stolen easily. So, a more complicated scheme is needed to provide a secure tracing against eavesdropping and spoofing. In Sect. 3, we discuss more integrity problems and applications for which, an anti-counterfeiting RFID protocol can be applied. The focus of this work concerns the use of RFID as an integrity tool, in particular its use in an anti-counterfeiting system. In addition, we assume that the applications will require consumer/bearer privacy. That is any successful anti-counterfeiting/integrity RFID protocol must preserve tag owner/bearer (those parties that “possess” the tagged product) privacy. An outline of this chapter is as follows: First, we provide an introduction. We then provide a brief discussion RFID technology. Next, we discuss the potential of using RFID as an anti-counterfeiting tool and applications. We then discuss security design criteria. After that we discuss re-encryption, an anonymity cryptographic tool that can be used for privacy. We then construct a generic integrity (anti-counterfeiting) protocol, which satisfies the integrity model while preserving bearer privacy.

8.5 Man-In-Middle Attacks on RFID Systems

Depending on the system configuration, a man-in-the-middle attack is possible while the data is in transit from one component to another. An attacker can interrupt the communication path and manipulate the information back and forth between RFID components. This is a real-time threat. The attack will reveal the information before the intended device receives it and can change the information en route. Even if it received some invalid data, the system being attacked might assume the problem was caused by network errors, but would not recognize that an attack occurred. An RFID system is particularly vulnerable to Man-in-the Middle attacks because the tags are small in size and low in price.

8.6 Digital Signature

Digital signature systems are adopted worldwide. Using the legally valid digital signatures for payment orders demands involving the strong security mechanisms to prevent secret keys leakage or unauthorized use and other possible risks. Typically, digital signature calculation is performed by cryptographic smart cards or USB tokens containing secrets keys. Personal computers with digital signature systems are usually equipped with access control and management systems that allow to provide restricted access to the computers and to supervise processes running on them. However, it keeps some possibilities of attacks on digital signature systems, mainly resulting from incorrect or erroneous user behavior. We propose to use RFID technology to combine functions of physical access control, computer's access control and management, and digital signature systems. This combination allows to drastically increase systems' security. Even low-end RFID tags can add one security level into the system, but high-end RFID tags with cryptographic possibilities and slight modification of digital signature calculation procedure make it possible to prevent obtaining digital signatures for fraudulent documents. The further evolution of the proposed scheme is permanent monitoring by means of periodical controlling user's RFID tag, whether authenticated user is present at the computer with restricted access.

8.7 Transponder

The Digital Signature Transponder (DST) is a cryptographically enabled Radio-Frequency Identification (RFID) device used in a variety of wireless authentication applications. The largest deployments of the transponder include the Exxon-Mobil Speedpass payment system (approximately 7 million transponders), as well as a variety of vehicle immobilizer systems used in many late model Ford, Lincoln, Mercury, Toyota, and Nissan vehicles.

The DST is an unpowered “passive” transponder which uses a proprietary block cipher to implement a challenge-response authentication protocol. Each DST tag contains a quantity of non-volatile RAM, which stores a 40-bit encryption key. This key is used to encipher a 40-bit challenge issued by the reader, producing a 40-bit ciphertext, which is then truncated to produce a 24-bit response transmitted back to the reader. Verifiers (who also possess the encryption key) verify this challenge by computing the expected result and comparing it to the tag response. Transponder encryption keys are user programmable, using a simple over-the-air protocol. Once correctly programmed, transponders may be “locked” through a separate command, which prevents further changes to the internal key value. Each transponder is factory provisioned with a 24-bit serial number and 8-bit manufacturer code. These values are fixed, and cannot be altered.

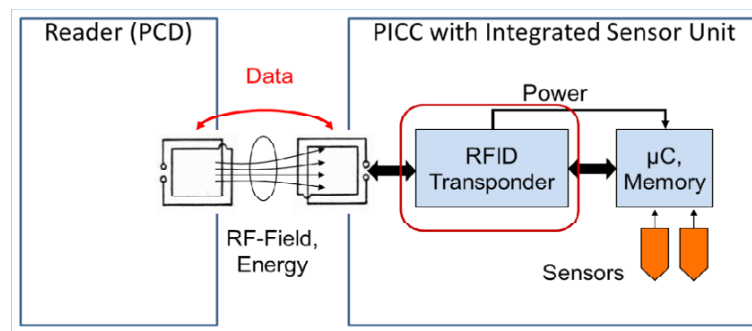


Fig 8.3 Transponder in the Proximity Integrated Circuit Card

8.8 Combining Physics and Cryptography to Enhance Security and Privacy in RFID Systems

8.8.1 Introduction

It is envisioned that in the near future RFID tags will be as ubiquitous as bar codes are today and, in fact, even more pervasive as they are expected to be embedded in every object from clothes to posters, from microwaves to food packages, from the smallest to the largest, thus enabling the so-called Internet of Things. The pervasiveness of RFID tags, their ability to carry more information than bar codes, their expected low cost, and their lack of need for line of sight communication also pose interesting challenges to? Work performed while at Philips Research Laboratories, The Netherlands those interested in their widespread adoption. Such challenges include both privacy and security concerns. On the privacy front, one can identify concerns on the part of consumers who will be carrying tagged objects. In particular, the wireless communication capabilities of RFID tags and their simple functionality (when queried they simply

reply with their unique identifier) could make it easier to track people based on tag identifiers as well as to find out consumer preferences clandestinely. Similarly, companies and government organizations will also be more vulnerable to espionage as it will be much easier to gather information on the competition or the enemy and much harder to detect such spying activities. The reader to the surveys for a comprehensive survey of privacy issues in RFID. On the security front, there is the authentication problem. In other words, how a legitimate party can assess whether an RFID tag embedded in an object (and thus the object itself) is authentic or not. The ability to authenticate legitimate tags has direct implications on industry's ability to decrease the counterfeit market, which in 2004 was expected to surpass the 500 billion USD per year mark. Thus, it is clear that solutions for authentication and privacy in RFID systems need to be developed. In fact, one can see, both the academic and business communities have dedicated a lot of effort to these problems. Based on the solutions that are known today, security and privacy solutions for RFID is divided into two groups: algorithmic solutions and solutions that either combine cryptography and physical principles, or that simply take advantage of a physical process. By algorithmic solutions, we mean those solutions based on traditional cryptographic mechanisms (e.g. public-key and symmetric-key primitives) or mechanisms which have been developed explicitly for the RFID environment but which make use of some type of cryptographic primitive (even if the primitive in question is not a standardized one, such as the AES). Examples of RFID security solutions based on algorithmic methods include: basic access control through passwords as specified in standards, minimalistic cryptography and lightweight protocols, solutions based on symmetric-key cryptography, hash functions, and elliptic curve-based solutions. However, at the present moment, solutions based on traditional public-key cryptography, symmetric-key cryptography, and hash functions are out of the question for the cheapest of RFID tags. Notice that the "low cost" requirement is an economics requirement. On the one hand, RFID tags are envisioned as more powerful substitutes for bar codes. On the other hand, if they are to be widely deployed (as bar codes are) then they also need to be in the same price range as a bar code, which only requires ink to be printed on a given item and thus, has cost close to zero. In the search for cheaper solutions, researchers have turned away from algorithmic approaches. Thus, ideas have been developed such as the kill command⁵, the blocker tag and similar blocking/proxy mechanisms. More engineering-oriented approaches have also been introduced such as the IBM clipped tags or distance bounding protocols. Finally, it is seen that the development of techniques that take advantage of noise in the communication channel between reader and tag to camouflage their communication. In other words, approaches that combine the physical properties of RFID tags (or their environment) with traditional

cryptographic primitives or that simply make use of physics to enhance the privacy friendliness and security of tags. Several additional mechanisms to enhance privacy and security of RFID tags have been proposed. Some proposals combine environmental information to disable or enable the RFID tag. Although the combination of sensors with RFID tags is not new, the realization that such environmental information can be used to enhance privacy is. A second possibility that is explored is the use of delays in revealing a secret key used to later establish a secure communication channel. These solutions will enhance other security and privacy solutions. It is possible that such methodology will in the end be the way towards securing RFID. The remainder of this contribution is organized as follows.

8.8.2. Physics at the Service of Privacy

In this section, two solutions that enhance the privacy of users carrying objects with embedded RFID tags are described. They assume the integration of sensors in the RFID tag functionality. Two questions may arise: whether this is possible at all and if this can be done in a battery-free manner.

In what follows, two scenarios which take advantage of embedded sensor functionality in an RFID tag to make the technology more privacy friendly.

a) Tag Privacy Protection Via Moisture Dependent Contact

It is envisioned that RFID tags will be embedded in clothing to support activities such as supply chain and retailer product management. In addition, such tags could also support other applications such as smart washing machines. Smart washing machines could be equipped with an RFID reader, which allows the machine to access clothing information. Therefore, the machine could autonomously select a washing program based on that information as well as it could advise the user to remove an item which needs a different washing program. However, including RFID tags in clothing raises privacy concerns to those that wear such garments. To enhance the privacy of users in this situation, a modified tag is proposed. The tag operates normally prior to sale. At the point of sale, the tag is disabled, e.g. by burning a ROM component or wire, which can be done by applying a large amount of power to the tag at the point of sale reader/terminal. Notice that we do not completely kill the tag but rather disable its RF interface. Once in the disabled state, the tag can still function but only if enough conducting moisture is present. This can be done by means of a switch (put in a strategic location such as the tag's antenna) that can only make electric contact if conducting liquid is present. Therefore, the tag

is effectively disabled in the street (as long as it stays dry) and can be finally re-enabled when the washing machine pumps water onto the clothes. One may worry that tag readout is hampered by large volumes of water absorbing RF radiation. However, studies have shown that this is not a problem. In particular, it is well known that at low frequencies (in the 10 to 20 MHz range) water is transparent to an RF signal. At higher frequencies, the attenuation is significant and it is highly frequency dependent. For example, the study shows that the attenuation of the signal travelling a distance of 6 cm varies between 7 dB and 23.5 dB for frequencies between 100 MHz and 950 MHz. Notice, however, that there are starting to appear solutions which can perform well in the presence of water and metals at high frequencies. Finally, for the particular case of an RFID-tag operating in the 13.56 MHz band, a weakening of the signal by 10 dB is deemed acceptable. It can be shown experimentally that at frequencies around 10 MHz the RF signal penetrates 25 cm into salty liquid, which is more than sufficient for the washing machine example.

b) Tag Privacy Protection Via Light Controlled Tag Activation

In this section, we describe the idea of controlling access to the powering circuit of the RFID tag via a fully integrated light-sensitive diode which can detect the presence of a laser-beam, e.g., from a laser pointer. This allows for the presence of a secure light-controlled ON/OFF switch on the tag. When the tag is powered by a reader and a laser-beam is pointed at the light-sensor, a digital ON code is written in the RFID's non-volatile memory. This ON code can, by means of an active switch (e.g., a MOS-transistor), be used to enable the power-supply voltage to parts of the RFID-chip, or enable other circuits to the rest of the chip, in such a way that the chip becomes fully functional. Even when the tag is taken out of the reader field, this ON state remains stored in memory. The tag can also be set in its OFF mode under similar conditions. When the tag is powered by a reader and a laser beam is pointed again to the light-sensor, then an OFF bit will be written in non-volatile memory and the power-supply voltage is disabled from the rest of the tag. In that case, the tag is not functional anymore until it is switched ON again by means of the laser beam. As with the moisture dependent switch, a consumer carrying items with such a modified RFID tag could disable the tag at the point of sale terminal and re-enable it again once he/she is in a safe environment, e.g., home. Thus, future ambient intelligent applications would still be supported and the user's privacy not affected. Clearly, a potential attacker, intending to track someone via the RFID tags that his victim is carrying, would be required to point a light source at each consumer tag that needs to be enabled without this activity being detected by the victim. Even though such a switch provides

the desired functionality of access control to the tag, it suffers from the drawback that a laser beam needs to be pointed to the tag. Thus, this could be considered as undermining one of RFID's main advantages: no line of sight communication. As an alternative, it is also possible to make an RFID tag that will only function if enough environmental light is present. In this case, the user can protect his tags from being read out by an unauthorized party simply by covering the tag such that no light can reach its photo detector or by keeping the tags in the dark. Notice that in many situations, this would not be an unnatural thing to assume (just think of a grocery bag). Alternatively, an RFID tag could be part of a label that can be closed or opened (covered/uncovered) such that light to the tag is blocked or passed, respectively. This way the user is in control of the readout of his tags and can choose when and where her tags may be read. No special reader is required for reading out the RFID tag. The silicon-area required for the light-sensitive diode, including control circuits, can be very small. This results in a cheap protection method that can be, if necessary, combined with other existing privacy enhancing technologies. As a final remark notice that the idea of a light switch is similar in flavor to that of a Faraday cage enclosing a passport that only allows reading of the passport's contents when the metallic cover surrounding the passport is physically opened.

8.9 Scalability Issues in Large Scale Applications

RFID provides more data at the edge today than ever before, and the amount of information available will grow with increased volumes, read points and tagging locations. Managing this vast amount of information requires a simple way to collect, filter and transfer and transport data. In addition, the system should be configured to provide a seamless interface to current and future business systems, as well as an upgrade path to support multi-site applications. The right edgware provides a foundation for scalability from a simple RFID printer to an automated installation. It also has the modularity needed to support additional devices as they become available. In addition, localized edgware provides a level of redundancy that will allow intelligent operation through event-based workflows. RF Expertise—Getting the System Right Experience counts in designing a quality RFID system. To ensure that the system is designed properly, it is essential to work with a company that has experience with and an understanding of RF to fine-tune the system. Steps to follow to ensure proper operation include:

- Performing a SKU analysis to determine if the products being processed are compatible with radio frequencies.
- Verification of the RF working environment.

- Automation analysis to provide guidance on moving from manual to automated materials handling
- Integration analysis to ensure that the RFID system integrates into the existing facility seamlessly, and with the least amount of disruption.

Verification: Radio frequencies present in the workplace can have a significant effect on the reliability of an RFID system. To ensure success, the system supplier must first assess whether large amounts of metal or stray radio waves are present in the environment and how they may affect operation.

Integration: Once the optimum solution has been chosen and a process is in place, it is easy to assume that the job is complete. In reality, however, only half the work is done. Now it is time to implement the solution. The challenge is to integrate the RFID system into the facility seamlessly with the least amount of disruption. To minimize problems and downtime, it is important to work with a company that has experience in working with both material-handling hardware and IT integration.

Scalability Options

In considering system-design options to ensure efficient operation today and scalability for tomorrow, one should consider the following questions:

- How are my labels applied today? Typically, manual systems are sufficient for low-volume tagging. Automated tagging solutions are appropriate when tagging 2,000 items per day, and may be appropriate for lower volumes if labels must be located more accurately to ensure readability.

- What is the present volume, and what will it be in the future? Answering this question provides guidance on when it might be appropriate to implement different solutions or combinations of solutions.

- What is the SKU mix? The main consideration here is whether the production line is dedicated to running a single product, or if it handles multiple products. If it is running only a single product, then one can take a batch-processing approach and the line may be configured for that specific product. If a company is handling multiple products, then each product or carton must be uniquely identified by a barcode scanner or the like to allow the system to differentiate among products.

Electronic Product Code (EPC) number management to ensure that the right data is programmed into the tag.

- Putting the right tag in the right location. The RFID system should indicate to the operator where to place the tag on specific products to ensure readability.

- Commissioning of product and pallet tags. The RFID system should be able to handle multiple tag form factors, and the ability to manage pallet and carton data.

- Production-reporting capabilities to indicate not only how much product is shipped, but also the system status.

- Integration into an existing IT system. As volumes grow, automation may offer more cost-effective scalability. Key data inputs to consider when automating include:

- Application Speed—Auto-applicators are six to 10 times faster than manual application.

- Cost of Labor—Labor costs are considerably higher for manual application.
 - Cost of Rejects—typically, the potential for rejects increases as the number of manually applied tags increases.

- Cost of Improperly Placed Tags—Automated solutions consistently place tags where designed, while manual solutions cannot guarantee proper placement.

Summary

- RFID technology can track the movements of objects through a network of radio-enabled scanning devices over a distance of several metres. A device called an RFID tag (or simply a tag) is a key component of the technology.
- Each tag contains a unique identity code. An RFID reader emits a low-level radio frequency magnetic field that energises the tag.
- RFID tags are considered “dumb” devices, in that they can only listen and respond, no matter who sends the request signal.
- RFID chips are quite similar to bar code labels in that they typically work with a corresponding scanner or reader.
- RFID computing system is a technology whose use has become more and more diverse and has become pervasively applied in many environments.

- Typically, digital signature calculation is performed by cryptographic smart cards or USB tokens containing secrets keys. Personal computers with digital signature systems are usually equipped with access control and management systems that allow to provide restricted access to the computers and to supervise processes running on them
- The Digital Signature Transponder (DST) is a cryptographically enabled Radio-Frequency Identification (RFID) device used in a variety of wireless authentication applications.

Check your Answers

- 1) Explain briefly RFID Technology.
- 2) What are the components of an RFID Tag?
- 3) Write short notes on: RFID Tags and RFID Chips.
- 4) What are the vulnerabilities found in RFID Technology?
- 5) What is a DST?

References

- http://www.enigmaticconsulting.com/Communications_articles/RFID/RFID_protocols.html
- http://shodhganga.inflibnet.ac.in/bitstream/10603/129201/8/08_chapter%201
- <https://ieeaccess.ieee.org/special-sections-closed/radio-frequency-identification-security-techniques/>
- https://en.wikipedia.org/wiki/Digital_signature_transponder
- <https://www.cosic.esat.kuleuven.be/wissec2006/papers/32.pdf>
- <https://www.rfidjournal.com/articles/pdf?2862>

Model Question Paper
M.Sc., Cyber Forensics and Information Security
First Year - Second Semester
Core Paper - V
Network Security and Cryptography

Time : 3 Hours

Max Marks: 80

Section - A

Answer any Ten questions each in 50 words

(10 x 2 = 20)

1. What is a switch?
2. What is NIC ?
3. List down various Authentication Protocols
4. What is Generic Routing Encapsulation ?
5. What are the components of MPLS?
6. What is Fuzzing ?
7. What is Blue Jacking ?
8. What is Route Cache Bypass ?
9. What is RFID ?
10. What are different types of tags?

Section - B

Answer any Five of the following in 250 Words in Each

(5 x 6 = 30)

1. Write short notes on routers, switches and Repeaters.
2. Explain the Steps involved in PAP & CHAP.
3. Differentiate between SSL & TLS?
4. Describe the components of MPLS.

5. What are Zigbee attacks ?
6. How are Keys managed in Ad-hoc wireless network ?

Section - C

Answer the following in 500 words

(3 x 10 = 30)

1. Describe in detail major attacks at the Network layer associated with IP and their mitigation techniques.
2. Explain the following
 - a) IPSec AH and ESH
 - b) IPSec Building Blocks
3. What is RFID ? What are the Vulnerabilities in RFID Technology?